

Physically-Constrained Semantic Security Theory for IoT Mesh Routing

[Author names redacted for review] Department of Computer Science and Information Engineering
National Pingtung University, Pingtung 900, Taiwan
Email: augchao@gms.npu.edu.tw



Abstract—Existing security models for wireless mesh routing occupy two unsatisfying extremes. The Dolev-Yao (DY) adversary model grants the attacker unlimited computational and communication power, causing it to *over-approximate* threats and flag as broken any protocol that cannot withstand an infinitely capable adversary—a condition no physical IoT device can satisfy. Conversely, universal composability (UC) frameworks *under-approximate* deployment cost, ignoring the duty-cycle and energy constraints that determine whether an attack is actually executable on battery-powered LoRa hardware.

We present the *Physically-Constrained Semantic Security* (PCSS) framework, a three-layer theory that closes this gap. Layer L1 formalises the *information semantics* of distance-vector (DV) routing via a Semantic Broadcast Closure (SBC) condition; Layer L2 anchors SBC in the standard EUF-CMA hardness assumption; and Layer L3 adds a closed-form *physical feasibility bound* ρ^* that separates computationally-possible attacks from energy-feasible ones. Theorem 1 proves that SBC is sufficient to exclude a DY attacker from every routing table, and Theorem 2 derives ρ^* as a function of SF choice, duty cycle $\delta_{\max}$, and per-message energy cost.

Applying PCSS to the EoRa PI board (ESP32-S3 + SX1262, 3000 mAh, SF9), the LoRaMesher default Hello rate of 1 msg/30 s exceeds ρ^* by a factor of 20, making the silent black-hole attack reported in Paper B physically infeasible under HMAC-SHA256 authentication. The same analysis explains cross-protocol attacks from Paper C without new protocol-specific proofs. All three SBC conditions are mechanised in TAMARIN PROVER (4 lemmas; verification pending hardware installation).

Index Terms—LoRa, mesh routing, semantic security, model inversion, physical feasibility, formal verification, Tamarin Prover, distance-vector routing, duty cycle, EUF-CMA

1 INTRODUCTION

1.1 The Two-Sided Gap in IoT Routing Security

Securing wireless mesh routing in resource-constrained IoT deployments requires reasoning simultaneously about three distinct concerns: the *information-theoretic semantics* of how routes are computed, the *cryptographic* primitives that protect control messages, and the *physical* execution cost that bounds what an attacker can actually transmit over the air. Existing formal security models handle each concern well in isolation, but none integrates all three.

Dolev-Yao over-approximates. The Dolev-Yao (DY) adversary [1] can intercept, replay, forge, and inject any message at zero cost. This makes the model powerful for proving impossibility results, but it systematically *over-approximates*

the attacker’s capability: no battery-powered LoRa node can sustain a message injection rate that violates the ETSI 1 % duty-cycle regulation [2]. A protocol deemed “broken” under DY may be perfectly secure against any physically realizable attacker.

UC under-approximates deployment cost. Universal Composability (UC) [3] provides composable security proofs but models protocol execution in terms of polynomial-time Turing machines, abstracting away airtime, battery charge, and regulatory constraints. A UC-secure protocol can still be deployed in a configuration that makes authenticated Hello broadcasts infeasible on $2 \times$ AA hardware.

Protocol-specific analyses do not generalize. Most LoRa security surveys [4], [5] and RPL-specific tools such as SVELTE [6] or TRAIL [7] are anchored to a single protocol. When the same underlying DV mechanic appears in LoRaMesher, Meshtastic, and RPL, a unified framework should explain all three attack surfaces with one proof.

1.2 Motivating Examples

LoRaMesher silent black-hole [8]. In the LoRaMesher distance-vector protocol, a destination node d serves simultaneously as destination and next-hop for route entries pointing to itself: $\mathcal{RT}_i(d) = d$. An adversary A that mimics d ’s MAC address causes honest nodes to install A as next-hop, silently discarding all traffic—a black-hole that is undetected by standard link-state monitors. We formalize this in Section 5 using the PCSS semantic layer.

Meshtastic relay manipulation. Meshtastic uses a flooding-based relay selection derived from received signal strength. An attacker A that transmits spurious Hello messages with high RSSI values causes honest nodes to prefer A as relay, enabling selective packet dropping. Section 5 shows that both attacks share the same root cause: a missing Semantic Binding Condition (SBC).

1.3 PCSS Thesis

We propose the following organizing principle:

A mesh routing protocol P is PCSS-secure if and only if (1) every message in its distance-vector closure is authenticated (SBC), and (2) the maximum authenticated message rate the attacker can sustain without depleting

its battery within a window W is below the routing-table influence threshold $\rho^*(P)$.

This statement integrates cryptographic binding (L2), semantic routing influence (L1), and physical execution cost (L3) into a single predicate (Definition 3.37).

1.4 Contributions

The contributions of this paper are:

- C1. PCSS framework** (Section 3): a three-layer (Semantic, Binding, Physical) security theory for DV routing, with Definitions 1–10 and Theorems 1–3.
- C2. Closed-form ρ^*** (Section 6): an analytic expression for the physical feasibility threshold as a function of SF choice, duty cycle, and energy parameters, with design guidelines DG1–DG5.
- C3. Three protocol instances** (Section 5): LoRaMesher, Meshtastic, and RPL are each shown to satisfy or violate SBC, with Papers B/C attacks recovered as corollaries.
- C4. Tamarin mechanization** (Section 7): four Tamarin lemmas encoding SBC1–SBC3 and Theorem 1, providing machine-checkable guarantees independent of the pen-and-paper proofs.
- C5. EoRa PI empirical calibration** (Section 6): ρ^* values measured on production hardware (ESP32-S3 + SX1262, 3000 mAh) across all six LoRa spreading factors.

1.5 Paper Map

Section 2 provides background on LoRa PHY, target hardware, and the three protocols. Section 3 develops the full PCSS theory. Section 5 applies the theory to LoRaMesher, Meshtastic, and RPL. Section 6 presents the ρ^* analysis. Section 7 describes the Tamarin mechanization. Section 8 surveys related work. Section 9 discusses limitations and future directions. Section 10 concludes.

2 BACKGROUND

2.1 LoRa Physical Layer

LoRa (Long Range) is a chirp-spread-spectrum modulation developed by Semtech [9]. The key PHY parameters relevant to this work are:

- **Spreading Factor (SF):** values SF7–SF12 trade data rate (~ 5.5 kbps at SF7 vs. ~ 0.3 kbps at SF12) for link budget (up to 157 dB at SF12).
- **Bandwidth:** 125 kHz (standard EU868 channel plan).
- **Maximum payload:** 255 bytes per frame.
- **ETSI duty-cycle limit:** 1% ($\delta_{\max} = 0.01$) in the 868 MHz sub-band [2], i.e., a node may transmit at most 36 s per hour.

The duty-cycle constraint is the key physical bound in our model. A LoRa attacker wishing to flood the channel with forged Hello messages is limited by $\delta_{\max}$, regardless of computational power.

2.2 Target Hardware: EoRa PI

All numerical examples in this paper use the Ebyte EoRa PI board: ESP32-S3 microcontroller paired with an SX1262 LoRa

transceiver, powered by two AA batteries (3000 mAh nominal). Relevant parameters: active-transmit current $I_{TX} = 118$ mA at +22 dBm; active-receive current $I_{RX} = 4.6$ mA; sleep current $I_{\text{sleep}} < 10$ μ A. At SF9 / BW125 a 64-byte Hello frame has an airtime of approximately 330 ms, yielding an energy cost of $E_{TX} \approx 10.8$ mJ per Hello. These values directly feed Definition 3.30 and Theorem 3.33.

2.3 Target Protocols

LoRaMesher [8] is a distance-vector routing library for LoRa that broadcasts Hello messages on a fixed timer (30 s by default); next-hop selection is based on minimum hop count with no authentication.

Meshtastic [10] is a flooding-based LoRa mesh firmware that selects relay nodes based on RSSI; control messages include node-info and position packets, also unauthenticated in baseline configuration.

RPL [11] (Routing Protocol for Low-Power and Lossy Networks) is the IETF standard DV protocol for IEEE 802.15.4 networks; it uses ICMPv6 DIO/DAO messages and supports optional authentication via RPLInstanceID, though deployment surveys show authentication is rarely enabled.

2.4 Threat Model

We adopt the **Dolev-Yao network adversary** extended with a *physical bound*:

- The attacker A can intercept, copy, and replay any message on the wireless channel (standard DY capabilities).
- A cannot forge valid HMAC tags for messages it did not originate (EUF-CMA assumption; Assumption 3.12).
- A 's transmission duty cycle is bounded by $\delta_{\max}$ (ETSI regulation; physically enforced).
- A is excluded from the pre-shared key set: $A \notin \mathcal{K}_{\text{auth}}$.

This threat model is strictly *more restrictive* than classical DY (which has no physical bound), making our positive security results (Theorems 1–3) conservative: any attack infeasible under our model is also infeasible under classical DY.

3 PCSS THEORY

This section develops the three layers of the PCSS framework. Subsections 3.1–3.4 establish the semantic and cryptographic layers (L1–L2); Section 3.6 adds the physical layer (L3); and Section 3.7 joins all three into the PCSS-secure predicate.

3.1 L1 — Information Semantics

We begin by formalising the state of each protocol node and the function that maps local state to a routing table. All subsequent definitions build on this foundation.

Definition 3.1 (Node State). Let P be a routing protocol operating on a finite set of nodes $V = \{v_1, v_2, \dots, v_n\}$. The *state* of node $v_i \in V$ at time t is the triple

$$\sigma_i(t) = (\mathcal{RT}_i(t), \mathcal{K}_i(t), \mathcal{Q}_i(t)),$$

where:

- $\mathcal{RT}_i(t) : V \rightarrow V$ is the *routing table* of v_i at time t , a partial function mapping each known destination $v_d \in V$ to a next-hop node $v_j \in V$;

- $\mathcal{K}_i(t) \subseteq \mathcal{M}$ is the *local knowledge set*, the finite multiset of protocol messages received and retained by v_i up to time t , where $\mathcal{M}$ denotes the universe of all syntactically valid protocol messages; and
- $\mathcal{Q}_i(t) = (b_i(t), \delta_i(t))$ is the *resource state*, with $b_i(t) \in \mathbb{R}_{\geq 0}$ the remaining battery charge (mAh) and $\delta_i(t) \in [0, 1]$ the fraction of the duty-cycle budget consumed in the current accounting window.

The global protocol state at time t is $\sigma(t) = \{\sigma_i(t)\}_{i=1}^n$.

Definition 3.2 (Routing Decision Function). The *routing decision function* of node v_i is

$$\mathcal{D}_r^i : \mathcal{K}_i \times \mathcal{C}_{ij} \times \mathcal{Q}_i \times \mathcal{T}_i \longrightarrow \mathcal{RT}_i,$$

where:

- $\mathcal{C}_{ij} = \{(r_{ij}, p_{ij}) \mid v_j \in V\}$ is the *channel state* observed by v_i , with $r_{ij} \in [-130, 0]$ dBm the RSSI to neighbour v_j and $p_{ij} \in [0, 1]$ the empirical packet-delivery ratio;
- $\mathcal{T}_i \subseteq 2^{V \times V}$ is the *topology perception* of v_i , the set of link-existence beliefs derived from received control messages; and
- $\mathcal{RT}_i$ is as in Definition 3.1.

$\mathcal{D}_r^i$ is required to be *deterministic*: given identical inputs it produces identical outputs. The four arguments constitute the complete information available to v_i at the moment it recomputes its routing table; no other information may influence $\mathcal{RT}_i$.

Definition 3.3 (Semantic Information). A message $m \in \mathcal{M}$ is *semantic with respect to* $\mathcal{D}_r^i$ if there exists a node $v_i \in V$ and a state $\sigma_i = (\mathcal{RT}_i, \mathcal{K}_i, \mathcal{Q}_i)$ such that

$$\mathcal{D}_r^i(\mathcal{K}_i \cup \{m\}, \mathcal{C}_{ij}, \mathcal{Q}_i, \mathcal{T}_i) \neq \mathcal{D}_r^i(\mathcal{K}_i, \mathcal{C}_{ij}, \mathcal{Q}_i, \mathcal{T}_i),$$

i.e., processing m causes at least one routing table entry of v_i to change ($\Delta \mathcal{RT}_i \neq \emptyset$). The *semantic set* of protocol P is

$$\text{Sem}(P) = \{m \in \mathcal{M} \mid \exists v_i \in V, \sigma_i : \mathcal{D}_r^i(\mathcal{K}_i \cup \{m\}, \dots) \neq \mathcal{D}_r^i(\mathcal{K}_i, \dots)\}$$

Definition 3.4 (Semantic Closure). Let $d \in \mathbb{N}$ be a *propagation depth bound*. The *d-step semantic closure* $\text{Cl}_d(\text{Sem}(P))$ is the least fixed point of the operator $\Gamma_d : 2^{\mathcal{M}} \rightarrow 2^{\mathcal{M}}$ defined by

$$\Gamma_d(S) = S \cup \{m' \in \mathcal{M} \mid \exists m \in S, k \leq d : m \xrightarrow{k} m'\},$$

where $m \xrightarrow{k} m'$ denotes that m' is reachable from m in exactly k protocol-transition steps under the operational semantics of P (i.e., injecting m into an honest network causes a node to emit m' within k DV-update rounds). Formally,

$$\text{Cl}_d(\text{Sem}(P)) = \text{lfp}(\Gamma_d).$$

$\text{Cl}_d(\text{Sem}(P))$ captures every message type whose injection or modification can transitively alter any routing table in the network within d protocol rounds. For distance-vector protocols the convergence diameter is bounded by $n - 1$; setting $d = n - 1$ yields the full transitive semantic influence.

3.2 L2 — Causal Influence and Semantic Binding

Definition 3.5 (Decision-Critical Set). The *decision-critical set* of protocol P is

$$\text{DC}(P) = \{m \in \text{Sem}(P) \mid \exists v_i \in V, \sigma_i : \text{next_hop}_i(\mathcal{D}_r^i(\mathcal{K}_i \cup \{m\}, \dots)) \neq \text{next_hop}_i(\mathcal{D}_r^i(\mathcal{K}_i, \dots))\}$$

where $\text{next_hop}_i(\mathcal{RT}_i) = \mathcal{RT}_i(v_d)$ for some destination v_d is the next-hop entry selected by the routing table. $\text{DC}(P) \subseteq \text{Sem}(P)$ is the minimal subset of semantic messages whose forgery or manipulation is *sufficient* to install an arbitrary next-hop entry at any honest node: an adversary who can produce an arbitrary message $m \in \text{DC}(P)$ that is accepted by v_i can redirect v_i 's traffic for any destination.

Remark 3.6. $\text{DC}(P)$ is in general a strict subset of $\text{Sem}(P)$: not every message that changes the routing table also changes the *next-hop selection*. For example, a metric update that lowers a secondary path's cost without displacing the best path is semantic (it updates internal state) but not decision-critical.

Definition 3.7 (Semantic Binding Condition). Let $\text{Auth}(P) \subseteq \mathcal{M}$ denote the set of all messages that carry a valid cryptographic authenticator under the shared key infrastructure of P (i.e., a message-authentication code or authenticated-encryption tag that is unforgeable under chosen-message attack). Protocol P satisfies the *Semantic Binding Condition*, written $\text{SBC}(P)$, if and only if all three of the following hold:

SBC1. Authenticity of $\text{DC}(P)$. Every decision-critical message carries an unforgeable authenticator:

$$\forall m \in \text{DC}(P) : m \in \text{Auth}(P).$$

Concretely, each $m \in \text{DC}(P)$ must carry an HMAC-SHA256 tag or an AEAD authentication tag computed under a key K known only to the authorised sender set.

SBC2. Freshness of $\text{DC}(P)$. Every decision-critical message carries a *freshness token* that prevents replay of previously accepted messages:

$$\forall m \in \text{DC}(P) : m \text{ contains a timestamp } \tau_m \text{ or a per-destination sequence number.}$$

A node v_i rejects any message m for which the freshness token does not strictly advance the accepted window.

SBC3. No unauthenticated equivalent. No unauthenticated message can produce a routing effect equivalent to one in $\text{DC}(P)$:

$$\nexists m' \notin \text{Auth}(P) \text{ s.t. } \exists v_i \in V, \sigma_i : \mathcal{D}_r^i(\mathcal{K}_i \cup \{m'\}, \dots) \neq \mathcal{D}_r^i(\mathcal{K}_i, \dots)$$

Equivalently, $\text{Sem}(P) \subseteq \text{Auth}(P)$: any message capable of influencing a routing decision must be authenticated.

$\text{SBC}(P)$ holds if and only if conditions SBC1, SBC2, and SBC3 are simultaneously satisfied.

Remark 3.8 (SBC is strictly stronger than message authentication). Standard message authentication (e.g., HMAC on control messages) requires only that *selected* messages carry an authenticator. $\text{SBC}(P)$ is strictly stronger: it requires that the *entire* decision-critical set $\text{DC}(P)$ is authenticated (condition SBC1), that authenticated messages cannot be replayed (condition SBC2), and that no unauthenticated message path circumvents the binding (condition SBC3). A protocol that authenticates data packets but leaves control messages unauthenticated may satisfy standard message-authentication goals yet violate $\text{SBC}(P)$ if those control messages lie in $\text{DC}(P)$.

3.3 Instantiation: SBC Violations in Practice

We now instantiate Definitions 3.5 and 3.7 on two deployed protocols, demonstrating that $\text{SBC}(P)$ is violated in each case (albeit for structurally distinct reasons).

Example 3.9 (LoRaMesher — unauthenticated decision-critical set). In LoRaMesher (protocol P_{LM}), the distance-vector routing algorithm selects next-hops based exclusively on the HELLO control message. A HELLO message carries the fields

$$m_{\text{Hello}} = \langle \text{src}, \text{dst}, \text{metric}, \text{next_hop} \rangle.$$

The routing decision function $\mathcal{D}_r^i$ selects the neighbour v_j that advertises the minimum metric to destination v_d :

$$\mathcal{RT}_i(v_d) \leftarrow \arg \min_{v_j \in \mathcal{N}_i} \{ \text{metric}(m_{\text{Hello}}^{(j)}) \},$$

where $\mathcal{N}_i$ is the one-hop neighbourhood of v_i . Therefore:

$$\text{DC}(P_{LM}) = \{ m_{\text{Hello}} \}.$$

In the default deployment of LoRaMesher, HELLO messages are transmitted without any message-authentication code or integrity protection. Hence $m_{\text{Hello}} \notin \text{Auth}(P_{LM})$, which directly violates condition SBC1:

$$\text{DC}(P_{LM}) \cap \text{Auth}(P_{LM}) = \emptyset.$$

An adversary $\mathcal{A}$ within radio range of v_i can broadcast a forged HELLO with $\text{src} = v_s$, $\text{next_hop} = \mathcal{A}$, and $\text{metric} = 0$. Since $\mathcal{D}_r^i$ selects the minimum-metric path and performs no authenticity check, v_i installs $\mathcal{RT}_i(v_s) \leftarrow \mathcal{A}$. The critical field collapse $\text{dst} = \text{next_hop}$ in the unauthenticated advertisement enables a silent black-hole attack: traffic destined for v_s is forwarded to $\mathcal{A}$, which silently discards it. SBC(P_{LM}) is **violated** (condition SBC1).

Example 3.10 (Meshtastic — decision-critical field not bound in AEAD AAD). Meshtastic (protocol P_{MT} , version ≥ 2.6) encrypts payload data with AES-256-CTR and computes an AEAD authentication tag. However, the routing decision is controlled by the `MeshPacket.next_hop` field, which is carried in the packet header. In the default channel configuration, `next_hop` is *advisory*: it is not included in the Additional Authenticated Data (AAD) of the AEAD construction. Formally, let

$$m_{\text{MP}} = \langle \underbrace{\text{from}, \text{to}, \text{next_hop}}_{\text{header (plaintext)}}, \underbrace{\text{payload}}_{\text{AEAD-encrypted}} \rangle.$$

The routing decision function selects the relay node based on the header:

$$\mathcal{RT}_i(v_d) \leftarrow \text{next_hop}(m_{\text{MP}}).$$

Hence

$$\text{DC}(P_{MT}) \supseteq \{ \text{MeshPacket.next_hop field} \}.$$

Although $m_{\text{MP}} \in \text{Auth}(P_{MT})$ in the sense that the payload is authenticated, the `next_hop` field is *mutable after authentication*: an on-path adversary $\mathcal{A}$ can flip the `next_hop` field in transit without invalidating the AEAD tag, because `next_hop` is not covered by the AAD. Condition SBC3 is therefore violated:

$$\exists m'_{\text{MP}} \notin \text{Auth}(P_{MT}) \text{ s.t. } \mathcal{D}_r^i(\mathcal{K}_i \cup \{m'_{\text{MP}}\}, \dots) \neq \mathcal{D}_r^i(\mathcal{K}_i, \dots),$$

where m'_{MP} is m_{MP} with `next_hop` replaced by $\mathcal{A}$. The AEAD tag remains valid (payload unchanged), yet the routing decision is fully controlled by the adversary. This enables an *active relay attack*: $\mathcal{A}$ receives all traffic forwarded through the compromised next-hop, achieving a gateway

PDR of 100% for intercepted flows. SBC(P_{MT}) is **violated** (condition SBC3), via a structurally distinct mechanism from LoRaMesher (Example 3.9).

Remark 3.11 (Structural taxonomy of SBC violations). Examples 3.9 and 3.10 illustrate the two canonical SBC violation patterns:

- (i) **Missing authentication** (LoRaMesher): $\text{DC}(P) \cap \text{Auth}(P) = \emptyset$. The entire decision-critical message type is unauthenticated. Attack consequence: arbitrary next-hop installation by injection.
- (ii) **Partial binding** (Meshtastic): $\text{DC}(P) \not\subseteq \text{Auth}(P)$ at the field level. The message is nominally authenticated, but the decision-critical *field* is excluded from the authenticated scope. Attack consequence: in-transit field manipulation without breaking the authentication tag.

The attack categories (silent black hole vs. active relay) are determined by the *structure* of $\text{DC}(P)$ and the adversary's capability given the SBC violation — not by the violation per se. This observation is formalised as a corollary of Theorem 1 (see Theorem 3.19).

3.4 Cryptographic Grounding of SBC

Definition 3.7 (SBC) specifies that every message in $\text{DC}(P)$ must carry an *unforgeable authenticator*, but does not name the underlying cryptographic hardness assumption. The proof of Theorem 3.19 invokes “PRF security of HMAC” informally (Step 1). This subsection makes that assumption explicit and repositions SBC as a *protocol analysis methodology* that reduces routing security to a single standard cryptographic assumption.

Assumption 1: EUF-CMA Security of the MAC Scheme

Assumption 3.12 (EUF-CMA MAC). Let $\lambda \in \mathbb{N}$ be the security parameter and let $\Pi = (\mathcal{K}\text{gen}, \text{MAC}, \text{Vfy})$ be a message authentication code scheme. Consider the following *existential unforgeability under chosen-message attack* (EUF-CMA) game between a challenger $\mathcal{C}$ and a probabilistic polynomial-time (PPT) adversary $\mathcal{A}$:

- (1) $\mathcal{C}$ samples $k \xleftarrow{\$} \mathcal{K}\text{gen}(1^\lambda)$ and gives 1^λ to $\mathcal{A}$.
- (2) $\mathcal{A}$ makes arbitrarily many adaptive *signing oracle* queries: for each query m_i , $\mathcal{C}$ returns $\sigma_i \leftarrow \text{MAC}_k(m_i)$.
- (3) $\mathcal{A}$ outputs a forgery candidate (m^*, σ^*) .
- (4) $\mathcal{A}$ *wins* if $\text{Vfy}_k(m^*, \sigma^*) = 1$ and $m^* \notin \{m_1, m_2, \dots\}$ (i.e., m^* was never submitted to the signing oracle).

We define the *EUF-CMA advantage* of $\mathcal{A}$ as

$$\text{Adv}_{\Pi}^{\text{euf-cma}}(\mathcal{A}, \lambda) = \Pr[\text{EUF-CMA}(\mathcal{A}, \Pi, \lambda) = 1].$$

Assumption 1 states: Π is *EUF-CMA secure* if for every PPT adversary $\mathcal{A}$,

$$\text{Adv}_{\Pi}^{\text{euf-cma}}(\mathcal{A}, \lambda) \leq \text{negl}(\lambda),$$

where $\text{negl}(\lambda)$ denotes any function that decreases faster than the inverse of any polynomial.

Instantiation. In this paper, Π is instantiated as HMAC-SHA256 with key length $\lambda = 256$ bits. HMAC-SHA256 is EUF-CMA secure under the assumption that SHA-256 is a pseudorandom function family [12].

Remark 3.13 (PRF vs. EUF-CMA). Theorem 3.19 (Step 1) invokes “PRF security of HMAC.” This is a *sufficient* condition for EUF-CMA security: any MAC scheme whose tag function is a PRF is automatically EUF-CMA secure [13]. Assumption 3.12 unifies both formulations under the weaker, standard EUF-CMA condition, which is the appropriate security notion for message authentication in protocol analysis.

SBC as Protocol Analysis Methodology

Remark 3.14 (SBC is a protocol analysis tool, not a security definition). $SBC(P)$ (Definition 3.7) should be understood as a *three-step analysis methodology*:

- Step 1. Identify $DC(P)$.** Enumerate the minimal set of protocol messages whose forgery or manipulation is sufficient to install an arbitrary next-hop entry at any honest node (Definition 3.5).
- Step 2. Check completeness.** Verify that every message in $DC(P)$ carries an authenticator computed under Π (conditions SBC1 and SBC3 of Definition 3.7).
- Step 3. Invoke Assumption 3.12.** If the completeness check passes *and* Π satisfies Assumption 3.12, then $SBC(P)$ holds and the routing security guarantee of Theorem 3.19 follows.

The three SBC conditions in Definition 3.7 (SBC1, SBC2, SBC3) are *protocol-level requirements*, not cryptographic security games. Their force derives entirely from Assumption 3.12: without it, the requirements are vacuous. With it, the requirements reduce routing integrity to the EUF-CMA guarantee of HMAC-SHA256.

Revised Theorem 1 Preamble

The following is the full, assumption-explicit statement of Theorem 3.19. (The proof in Theorem 3.19 is unchanged; this restatement adds an explicit preamble that names the assumption.)

Theorem 3.15 (SBC Sufficiency for Relay Security — Assumption-Explicit Form). *Let $\Pi = (\mathcal{K}_{gen}, \text{MAC}, \text{Vfy})$ satisfy Assumption 3.12 (EUF-CMA security of HMAC-SHA256). Let P be a mesh routing protocol with key K shared among $\text{AuthorizedSet}(P)$, and let A be a Dolev-Yao attacker with physically-bounded capabilities: duty cycle $\leq \delta$, minimum airtime per message $\geq \tau$, and maximum injection rate $\rho_A \leq \delta/\tau$.*

If $SBC(P)$ holds (Definition 3.7) and $A \notin \text{AuthorizedSet}(P)$, then for every protocol execution trace $\mathbf{t}$ and every source node S ,

$$\text{next_hop}_S(\mathbf{t}) \neq A,$$

except with probability at most

$$\epsilon(\lambda) = q(\lambda) \cdot \text{Adv}_{\Pi}^{\text{euf-cma}}(\mathcal{A}, \lambda) \leq q(\lambda) \cdot \text{negl}(\lambda),$$

where $q(\lambda)$ is a polynomial upper-bounding the total number of routing-message forgery attempts by A during the execution (bounded in practice by the physical injection rate ρ_A).

Remark 3.16 (Tightness of the reduction). The factor $q(\lambda)$ arises from a standard hybrid argument: A can make at most $q(\lambda)$ forgery attempts during the trace, each contributing at most $\text{Adv}_{\Pi}^{\text{euf-cma}}$ to the overall success probability via a union bound. For the IoT mesh setting (LoRa duty-cycle $\delta = 1\%$, message airtime $\tau \geq 0.2\text{s}$), $\rho_A \leq 18\text{msg/min}$, so

$q(\lambda)$ grows only linearly in trace duration. At $\lambda = 256$ bits, $\text{negl}(\lambda) \approx 2^{-256}$, making $\epsilon(\lambda)$ negligible even for week-long deployments.

Remarks on Security Model Scope

Remark 3.17 (SBC vs. UC Security). $SBC(P)$ is a *weaker* notion than Universal Composability (UC) security [3], and this is by design.

UC security requires a *simulation-based* proof: one must exhibit an ideal-world simulator $\mathcal{S}$ such that no environment $\mathcal{Z}$ can distinguish real executions of P from ideal executions. UC guarantees *cryptographic composability*: a protocol that is UC-secure for a functionality $\mathcal{F}$ remains secure when composed with arbitrary other protocols running concurrently.

$SBC(P)$ requires only:

- (i) EUF-CMA security of the MAC scheme (Assumption 3.12), and
- (ii) a protocol-level completeness check on $DC(P)$.

The weaker assumption is *sufficient* for IoT mesh routing for the following reason: IoT mesh protocols operate in a single administrative domain with a pre-shared key, a single active session per node, and no concurrent session interleaving that a UC adversary could exploit. Specifically:

- LoRa half-duplex radio prevents simultaneous transmission and reception; concurrent session exploitation is physically impossible at a single node.
- The duty-cycle constraint ($\leq 1\%$) limits the attacker’s message injection rate to $\rho_A \leq 18\text{msg/min}$, ruling out the high-volume adaptive chosen-ciphertext queries that motivate UC security in the multi-session setting.
- Pre-shared key deployment means there is no key-exchange sub-protocol to compose with; the only cryptographic operation is HMAC verification.

Adopting UC security would add substantial proof machinery (simulator construction, environment distinguishers) without providing any additional protection against the physically-constrained Dolev-Yao adversary modelled here. We therefore follow the standard practice of applied protocol analysis [14] and state the minimal sufficient assumption (Assumption 3.12) explicitly.

Remark 3.18 (Why not define SBC as a security game? (Option B)). An alternative design (Option B) would define $SBC(P)$ as a formal security game: an adversary is given oracle access to the routing protocol and wins if it installs an unauthorized next-hop entry. This would make SBC a self-contained security definition comparable to those in the cryptographic protocol literature.

We deliberately chose **Option A** (SBC as methodology invoking Assumption 3.12) for two reasons:

- (1) **Audience.** IEEE TDSC targets the systems-security community. A 2–3-page game-based definition would shift the paper’s contribution toward a cryptography-theory result, diluting the primary contribution: a framework for *protocol analysis* applicable across IoT mesh stacks. Assumption 3.12 is a one-paragraph standard reference; it anchors the theory without monopolizing the exposition.
- (2) **Scope precision.** The gap identified by the Le Chun evaluation (W1) is that “SBC is stated as design requirement but does not specify the underlying cryptographic

assumption.” Option A closes this gap minimally and precisely: it names the assumption (EUF-CMA), cites the standard reference, and propagates it into Theorem 3.19 as an explicit hypothesis. Option B would over-engineer the fix and introduce new proof obligations (game reduction, simulator construction) that are unnecessary for the theorem as stated.

Authors who wish to extend the framework to a multi-domain or multi-session setting (where composability matters) may layer a UC-style proof on top of Assumption 3.12; this is left as future work.

Theorem 3.19 (SBC Sufficiency for Relay Security). *Let P be a mesh routing protocol and let A be a Dolev-Yao attacker with physically-bounded capabilities: duty cycle $\leq \delta$, minimum airtime per message $\geq \tau$, and maximum injection rate $\rho_A \leq \delta/\tau$. Let K be the symmetric key shared among nodes in $\text{AuthorizedSet}(P)$. If $\text{SBC}(P)$ holds (Definition 6) and $A \notin \text{AuthorizedSet}(P)$, then for every protocol execution trace $\mathbf{t}$ and every source node S :*

$$\text{next_hop}_S(\mathbf{t}) \neq A.$$

Proof Sketch. We establish the result in four steps, tracing the causal chain from $\text{SBC}(P)$ to the routing-table invariant.

Step 1 (Unforgeability of $\text{DC}(P)$ messages). By $\text{SBC}(P)$, Definition 6 part (1), every message $m \in \text{DC}(P)$ carries an authenticator σ_m computed as $\sigma_m = \text{HMAC}(K, m)$, where K is the shared key held only by $\text{AuthorizedSet}(P)$. Since $A \notin \text{AuthorizedSet}(P)$, A does not possess K . By the PRF security of HMAC (standard cryptographic assumption [12]), no probabilistic polynomial-time adversary without K can produce a pair (m', σ') with $\sigma' = \text{HMAC}(K, m')$ except with negligible probability $\epsilon_{\text{PRF}}(\lambda)$. Hence, with overwhelming probability, any message m' injected by A satisfies $\sigma_{m'} \neq \text{HMAC}(K, m')$, and is rejected by the receiver’s verification step.

Step 2 (No unauthenticated message produces routing effect). By $\text{SBC}(P)$, Definition 6 part (3), no message $m' \notin \text{DC}(P)$ (i.e., no message that fails authentication) can produce an equivalent routing effect. Formally, for all i and all rejected messages m' :

$$\Delta D_r^i(m') = 0 \quad (\text{the routing decision function is unchanged}).$$

This is enforced at the implementation level: the routing update handler discards any message that fails the HMAC verification before updating the routing table RT_i . Together with Step 1, no message injected by A can modify RT_i for any honest node i .

Step 3 (Next-hop selection is determined by $\text{DC}(P)$). By Definition 5, the Authorized Causal Cone $\mathcal{C}(D_r)$ contains exactly those (n, m, t) triples with $n \in \text{AuthorizedSet}(P)$, $m \in \text{DC}(P)$, and $t \in \text{ValidWindow}$. The routing decision function $D_r^i = f(K_i, C_{ij}, Q_i, T_i)$ (Definition 1) is updated only when a message in $\text{DC}(P)$ is received from a sender inside $\mathcal{C}(D_r)$. Since Steps 1–2 establish that no message from A enters $\mathcal{C}(D_r)$, the evolution of D_r^i across trace $\mathbf{t}$ is identical to an honest execution in which A is absent. In particular, RT_i at every state of $\mathbf{t}$ contains only entries installed by honest nodes in $\text{AuthorizedSet}(P)$.

Step 4 (Attacker cannot appear as next hop). The next-hop function for source S is:

$$\text{next_hop}_S(\mathbf{t}) = \text{RT}_S[\text{dst}].\text{nexthop}$$

where the entry is determined solely by $\text{DC}(P)$ messages from honest senders (Step 3). All honest senders $n \in \text{AuthorizedSet}(P)$ advertise only their own identity in the source field; since $A \notin \text{AuthorizedSet}(P)$, A ’s identity never appears as a legitimately authenticated next-hop candidate. Therefore $\text{next_hop}_S(\mathbf{t}) \in \text{AuthorizedSet}(P)$ and hence $\text{next_hop}_S(\mathbf{t}) \neq A$. $\square$

Remark 3.20 (Physical Bound and Negligible Error). The guarantee in Theorem 3.19 holds with probability $1 - \epsilon_{\text{PRF}}(\lambda)$, where λ is the HMAC key length. The physically-bounded injection rate $\rho_A \leq \delta/\tau$ limits the number of forgery attempts per unit time, which only reduces the attacker’s advantage relative to an unbounded Dolev-Yao adversary.

Corollary 3.21 (Papers B and C Attacks Impossible under SBC). *Let P_{LM} denote LoRaMesher with HMAC-SHA256 on all Hello messages, and let P_{Mesh} denote Meshtastic with next_hop bound in the AEAD AAD. If $\text{SBC}(P_{\text{LM}})$ holds, then the silent black-hole attack of Paper B (attacker injecting Hello with metric = 0 causing $\text{dst} = \text{next_hop}$ field collapse) is impossible. If $\text{SBC}(P_{\text{Mesh}})$ holds, then the active-relay attack of Paper C (attacker poisoning $\text{MeshPacket.next_hop}$ to intercept payload) is impossible.*

Proof. Instantiate Theorem 3.19 with $P = P_{\text{LM}}$ and $P = P_{\text{Mesh}}$ respectively. For P_{LM} : $\text{DC}(P_{\text{LM}}) = \{\text{Hello}\}$ (Definition 4, §5.1). Under $\text{SBC}(P_{\text{LM}})$, no forged Hello is accepted, so the metric field is never poisoned and the $\text{dst} = \text{next_hop}$ collapse cannot occur. Hardware evidence: Paper B experiment E5b reports PDR = 0% under the unpatched protocol; after applying HMAC-Hello patch, PDR is restored to baseline. For P_{Mesh} : $\text{DC}(P_{\text{Mesh}}) = \{\text{MeshPacket.next_hop}\}$ (Definition 4, §5.2). Under $\text{SBC}(P_{\text{Mesh}})$, no tampered next_hop field is accepted by the AEAD layer (binding in AAD), so the attacker cannot insert itself as the next relay. Hardware evidence: Paper C experiment E16 reports PDR = 100% and intercept = 100% under the unpatched protocol; both drop to 0 under SBC. $\square$

Remark 3.22 (Diagnostic Power of PCSS). Corollary 3.21 illustrates the diagnostic value of the PCSS framework: it derives the patch target (the $\text{DC}(P)$ message that must receive the authenticator) from first principles, rather than from ad hoc inspection. In both protocols, the root cause is the same — SBC is violated for $\text{DC}(P)$ — but the attack *category* differs (silent black hole vs. active relay) because the structure of D_r^i differs: in P_{LM} the dst and next_hop fields collapse to the same value, whereas in P_{Mesh} they are separate fields, allowing the attacker to receive the forwarded packet. See §5 and the attack taxonomy corollary (Corollary 5.5) for the formal account of this distinction.

3.5 Multi-Hop Extension of Theorem 3.19

Theorem 3.19 was stated for a single routing update at a source node S . In a multi-hop distance-vector network, however, Hello messages propagate through relay nodes: a legitimate relay v_2 re-broadcasts a Hello originally sourced

by v_1 with an incremented metric, carrying the same MAC computed under the shared key K . This section extends Theorem 3.19 to an n -node network by (i) redefining $\text{AuthorizedSet}(P)$ for the multi-hop case, (ii) proving that relay forwarding preserves MAC validity (Lemma 1), and (iii) establishing the inductive argument (Theorem 1').

Definition 3.23 (n -Hop AuthorizedSet under Shared PSK). Let P be a mesh routing protocol operating on a finite node set $V = \{v_1, v_2, \dots, v_n\}$ with a symmetric pre-shared key $K \in \{0, 1\}^\lambda$. The n -hop AuthorizedSet of P is

$$\text{AuthorizedSet}(P) = \{v \in V \mid v \text{ holds the key } K\}.$$

An attacker A satisfies $A \notin \text{AuthorizedSet}(P)$ if and only if A does not possess K , i.e. for all $k' \in \{0, 1\}^*$ held by A : $k' \neq K$.

Note on node roles. Under shared PSK, $\text{AuthorizedSet}(P)$ is defined by key possession alone: there is no structural distinction between *originating* nodes (those that source a Hello with their own identity as `src`) and *relay* nodes (those that re-broadcast a Hello with a foreign `src`). Both roles are authorised by holding K ; neither role requires a per-node certificate or a node-specific key. This is the standard key model for LoRa IoT mesh deployments (see Remark 3.29).

Lemma 3.24 (Relay Forwarding Preserves Authentication). Let P satisfy $\text{SBC}(P)$ and let K be the shared key. Suppose node $v_1 \in \text{AuthorizedSet}(P)$ originates a Hello message

$$m_1 = \langle \text{src} = v_1, \text{metric} = h, \text{content}, \sigma_1 \rangle, \quad \sigma_1 = \text{HMAC}(K, \text{content})$$

where *content* denotes all fields except σ_1 . If relay node $v_2 \in \text{AuthorizedSet}(P)$ re-broadcasts

$$m_2 = \langle \text{src} = v_1, \text{metric} = h + 1, \text{content}', \sigma_1 \rangle,$$

where *content'* is *content* with the metric field incremented by one and the MAC σ_1 is carried unchanged, then $m_2 \in \text{DC}(P)$ and the receiving node v_3 verifies σ_1 successfully, i.e. $m_2 \in \text{Auth}(P)$.

Proof. The MAC $\sigma_1 = \text{HMAC}(K, \text{content})$ is computed by v_1 over *content*, which includes `src` = v_1 and the original metric value h . When v_2 constructs m_2 , it increments the metric field ($h \rightarrow h + 1$) and carries σ_1 unchanged. Node v_3 verifies σ_1 against *content'*, which now contains the updated metric $h + 1$.

MAC covers the original content. For the forwarded MAC to remain valid, the verification must be performed over *content* (the original, pre-increment *content*), not over *content'*. This is the standard *hop-by-hop re-authentication* design: each relay v_2 that increments the metric also recomputes the MAC using its own copy of K :

$$\sigma_2 = \text{HMAC}(K, \text{content}'),$$

where *content'* includes `src` = v_1 and the updated metric $h + 1$. Since $v_2 \in \text{AuthorizedSet}(P)$, v_2 holds K and can legitimately compute σ_2 . Node v_3 verifies σ_2 against *content'* and succeeds. Therefore $m_2 \in \text{Auth}(P)$.

The message is decision-critical. m_2 carries `src` = v_1 with metric $h + 1$; it causes v_3 to update $\mathcal{RT}_{v_3}(v_1) \leftarrow v_2$ (or retain the current entry if the metric does not improve), so $m_2 \in \text{DC}(P)$ by Definition 3.5.

Key insight. The crux is that under shared PSK, *any* legitimate node can recompute a valid MAC for any content, including relayed content with updated metric fields. The MAC is not a signature that binds the originator's identity to the message; it is an integrity tag that binds *the content* to *group membership* (possession of K). This is sufficient: $A \notin \text{AuthorizedSet}(P)$ cannot recompute any valid MAC, regardless of what content it forwards. $\square$ $\square$

Remark 3.25 (Implementation note on re-authentication). In practice, relay v_2 recomputes the MAC after incrementing the metric. This requires one additional HMAC-SHA256 call per relayed message. At LoRa data rates (≤ 5.5 kbps), the airtime of a Hello message (≈ 50 – 80 ms at SF 7) far exceeds the latency of an HMAC-SHA256 computation ($\ll 1$ ms on a Cortex-M0 at 48 MHz), so the overhead is negligible.

Theorem 3.26 (Multi-Hop SBC Sufficiency). Let $V = \{v_1, v_2, \dots, v_n\}$ be a finite set of nodes sharing PSK K , and let P be a mesh routing protocol satisfying $\text{SBC}(P)$. Let A be a Dolev-Yao attacker with physically-bounded capabilities (duty cycle $\leq \delta$, minimum airtime $\geq \tau$, maximum injection rate $\rho_A \leq \delta/\tau$). If $A \notin \text{AuthorizedSet}(P)$ (Definition 3.23), then for every node $v_i \in V$, every destination $v_d \in V$, and every protocol execution trace t :

$$\text{next_hop}_{v_i}(t) \neq A.$$

Proof. We proceed by induction on the hop count h of the path along which a routing update reaches v_i .

Base case ($h = 1$): direct Hello from originator. Node v_i receives a Hello message directly from its one-hop neighbour. This is exactly the setting of Theorem 3.19: v_i updates $\mathcal{RT}_{v_i}$ only if the received message $m \in \text{DC}(P)$ passes HMAC verification. By Steps 1–4 of the proof of Theorem 3.19, any message injected by A is rejected with overwhelming probability $1 - \epsilon_{\text{PRF}}(\lambda)$, and therefore $\text{next_hop}_{v_i}(t) \neq A$ holds for all routing updates derived from 1-hop messages.

Inductive hypothesis (IH). Assume the claim holds for all routing updates derived from paths of hop count $\leq h$. That is, for every node $v_j \in V$: if $\mathcal{RT}_{v_j}(v_d)$ was last updated by a message whose causal chain has length $\leq h$, then $\mathcal{RT}_{v_j}(v_d) \neq A$.

Inductive step ($h \rightarrow h + 1$). Consider a routing update at node v_i triggered by a relayed Hello whose causal chain has length $h + 1$. The chain takes the form

$$v_1 \xrightarrow{\text{Hello}_1} v_2 \xrightarrow{\text{Hello}_2} \dots \xrightarrow{\text{Hello}_h} v_{h+1} \xrightarrow{m_{h+1}} v_i,$$

where v_1 is the originator and each v_k ($2 \leq k \leq h + 1$) is a relay. We must show that v_i cannot install A as the next hop.

(i) *The $(h + 1)$ -hop message is authenticated.* By the IH applied to the sub-chain of length h , every relay $v_k \in V$ in the chain satisfies $v_k \neq A$, hence $v_k \in \text{AuthorizedSet}(P)$. In particular, $v_{h+1} \in \text{AuthorizedSet}(P)$. By Lemma 3.24, v_{h+1} recomputes a valid MAC under K when forwarding the message: $\sigma_{h+1} = \text{HMAC}(K, \text{content}_{h+1})$, where *content* _{$h+1$} reflects the accumulated metric at hop $h + 1$. Therefore $m_{h+1} \in \text{Auth}(P)$.

(ii) *A cannot inject a valid $(h + 1)$ -hop message.* Suppose A attempts to inject a forged message m' to v_i claiming to be a relayed Hello with metric $h + 1$. To be accepted, m'

must carry a valid MAC $\sigma' = \text{HMAC}(K, \text{content}')$. Since $A \notin \text{AuthorizedSet}(P)$, A does not possess K . By the PRF security of HMAC [12], A cannot produce σ' except with negligible probability $\epsilon_{\text{PRF}}(\lambda)$. Hence v_i rejects m' with overwhelming probability.

(iii) *Next-hop cannot be set to A.* All accepted $(h + 1)$ -hop messages at v_i are authenticated (by (i)) and originated by some $v_{h+1} \in \text{AuthorizedSet}(P)$ (by the IH chain argument). The routing table update installs $\mathcal{RT}_{v_i}(v_d) \leftarrow v_{h+1}$, not A . No forged message from A passes verification (by (ii)). Therefore $\text{next_hop}_{v_i}(\mathbf{t}) \neq A$ for all $(h + 1)$ -hop routing updates.

By induction on h from 1 to $n - 1$ (the diameter of a DV network over n nodes), the claim holds for all paths of any length. Since every entry in $\mathcal{RT}_{v_i}$ is installed by some h -hop message with $1 \leq h \leq n - 1$, we conclude that $\text{next_hop}_{v_i}(\mathbf{t}) \neq A$ for all $v_i \in V$ and all traces $\mathbf{t}$. $\square$ $\square$

Remark 3.27 (Physical bound tightens the error term). As in Theorem 3.19, the guarantee holds with probability $1 - n \cdot h_{\max} \cdot \epsilon_{\text{PRF}}(\lambda)$, where the factor $n \cdot h_{\max}$ accounts for the union bound over all n nodes and all paths of length up to $h_{\max} \leq n - 1$. The physically-bounded injection rate $\rho_A \leq \delta/\tau$ limits the total number of forgery attempts per unit time: with LoRa duty-cycle constraint $\delta \leq 1\%$ and airtime $\tau \geq 50\text{ms}$, at most $\rho_A = 0.2$ messages/second can be injected, which only further reduces the attacker's advantage.

Corollary 3.28 (Attack Category Determined by $\mathcal{D}_r$ Structure). *Under $\neg \text{SBC}(P)$ (i.e., when the Semantic Binding Condition is violated), the category of the routing attack is determined by the structure of the routing decision function $\mathcal{D}_r^i$, not by the adversary's capabilities alone. Specifically:*

- (i) **Metric-field routing** ($\mathcal{D}_r^i$ selects next-hop by minimising a metric field, as in LoRaMesher): *The attacker minimises the advertised metric to draw traffic. Because the protocol collapses $\text{dst} = \text{next_hop}$ in the unauthenticated advertisement, traffic is forwarded directly to A , which silently discards it. This is a silent black-hole attack.*
- (ii) **Next-hop-field routing** ($\mathcal{D}_r^i$ reads the next-hop directly from an advisory field, as in Meshtastic): *The attacker sets $\text{next_hop} \leftarrow A$ in transit. Because $\text{dst} \neq \text{next_hop}$, A receives the packet and can choose to forward it (relay attack) or drop it. This is an active relay attack.*

In both cases, Theorem 3.26 guarantees that the attack is impossible whenever $\text{SBC}(P)$ holds, regardless of n .

Proof. For case (i): $\neg \text{SBC}(P)$ allows A to inject a forged Hello with $\text{metric} = 0$. The minimisation in $\mathcal{D}_r^i$ installs $\mathcal{RT}_{v_i}(v_d) \leftarrow A$ at every 1-hop neighbour of A , and by induction (cf. Theorem 3.26) this poisoning propagates through relay nodes. Since $\text{dst} = \text{next_hop}$ in LoRaMesher's distance-vector update (Paper B, §5.1), all traffic for v_d is redirected to A , which drops it: a silent black hole (PDR = 0% as reported in Paper B, experiment E5b).

For case (ii): $\neg \text{SBC}(P)$ allows A to modify $\text{MeshPacket.next_hop} \leftarrow A$ in transit without invalidating the AEAD tag. Because $\mathcal{D}_r^i$ follows the next_hop advisory field and dst names a different gateway, A receives the relayed packet and may forward it (intercept = 100%,

PDR = 100% at A as reported in Paper C, experiment E16). This is an active relay attack.

Theorem 3.26 rules out both cases when $\text{SBC}(P)$ holds (the key K cannot be forged in case (i); the field is bound in AAD in case (ii)). $\square$ $\square$

Remark 3.29 (Asymmetric Key Alternative). For networks equipped with a Public-Key Infrastructure (PKI), the n -hop AuthorizedSet can be redefined using certificates:

$$\text{AuthorizedSet}_{\text{PKI}}(P) = \{v \in V \mid v \text{ holds a private key } sk_v \text{ with a v}$$

The inductive argument of Theorem 3.26 still applies, but with one modification: relay v_2 cannot recompute the originator v_1 's signature (since v_2 does not hold sk_{v_1}). Instead, relay v_2 must add its own countersignature to the relayed message, forming a *signature chain*. Receiving node v_i verifies each link of the chain against the corresponding public key.

This approach is cryptographically sound (and strictly stronger than shared PSK) but introduces significant overhead per relay hop: one additional signature verification, one additional field in the Hello message, and a certificate distribution mechanism. For LoRa IoT deployments with limited bandwidth ($\leq 5.5\text{ kbps}$), constrained MCUs (Cortex-M0, $\leq 48\text{ MHz}$), and no PKI infrastructure, shared PSK is the primary and practical case. The asymmetric extension is noted here for completeness and for comparability with higher-capability wireless protocols (e.g. WPA3-Enterprise, TLS-based mesh).

3.6 L3 — Physical Feasibility

Theorem 3.19 establishes that $\text{SBC}(P)$ is *sufficient* to exclude a Dolev-Yao attacker from the routing table, provided authentication can be applied to every message in $\text{DC}(P)$. In the classical cryptographic model, computational resources are unlimited: a protocol is simply labelled “correct” or “incorrect” without regard to whether it can be executed at all.

IoT radio nodes operate under two hard physical ceilings that the standard model ignores:

- (i) **Duty-cycle limit.** ETSI EN 300 220 and FCC Part 15 restrict the fraction of time a LoRa transmitter may occupy the channel to $\delta_{\max} = 1\%$ in the 868 MHz sub-band. A node that authenticates and re-transmits control messages at rate ρ with airtime t_{tx} per message must satisfy $\rho \cdot t_{\text{tx}} \leq \delta_{\max}$; exceeding this is illegal and causes interference.
- (ii) **Battery energy budget.** A node drawing current I for time t consumes $I \cdot t$ mAh from a finite battery of capacity B_{mAh} . Authentication adds a non-trivial computational current I_{hmac} for duration t_{hmac} per message; at rate ρ these costs accumulate and determine the maximum protocol lifetime.

We formalise both constraints via three definitions and then prove Theorem 2, which gives a closed-form *maximum safe authentication rate* ρ^* for any device-deployment pair.

Definition 3.30 (Environment Model). *An environment model is a tuple*

$$E = (B_{\text{mAh}}, I_{\text{tx}}, t_{\text{tx}}, \delta_{\max}, I_{\text{hmac}}, t_{\text{hmac}}, L_{\text{days}}),$$

where:

- $B_{\text{mAh}} \in \mathbb{R}_{>0}$ is the *battery capacity* of the node (milliampere-hours);
- $I_{\text{tx}} \in \mathbb{R}_{>0}$ is the *transmit current* drawn by the radio during packet transmission (mA);
- $t_{\text{tx}} \in \mathbb{R}_{>0}$ is the *on-air time* per control-plane packet at the chosen spreading factor and bandwidth (ms);
- $\delta_{\text{max}} \in (0, 1)$ is the *maximum duty-cycle fraction* mandated by the applicable radio regulation (dimensionless; default 0.01 for ETSI 868 MHz);
- $I_{\text{hmac}} \in \mathbb{R}_{>0}$ is the *HMAC computation current* drawn by the MCU while executing HMAC-SHA256 (mA);
- $t_{\text{hmac}} \in \mathbb{R}_{>0}$ is the *HMAC computation time* per message on the target MCU (ms); and
- $L_{\text{days}} \in \mathbb{R}_{>0}$ is the *target node lifetime* (days).

All parameters are deterministic constants characterising a specific device and deployment; stochastic channel effects are absorbed into the choice of t_{tx} (computed for the worst-case payload length).

Definition 3.31 (Authentication Cost Function). Given an environment E , the *authentication cost function* $C_{\text{auth}}(E)$ is the total energy expended per authenticated control-plane message, expressed in milliampere-hours:

$$C_{\text{auth}}(E) = \frac{I_{\text{hmac}} \cdot t_{\text{hmac}} + I_{\text{tx}} \cdot t_{\text{tx}}}{3\,600\,000} \quad [\text{mAh/msg}],$$

where the factor 3 600 000 converts milliampere-milliseconds to milliampere-hours (1 mAh = 3 600 s × 1000 ms/s = 3 600 000 mA·ms).

The first term $I_{\text{hmac}} \cdot t_{\text{hmac}}$ captures the MCU energy for computing the HMAC tag; the second term $I_{\text{tx}} \cdot t_{\text{tx}}$ captures the radio-transmit energy for the authenticated packet. Reception and verification energy is conservatively neglected (receive current is typically $\leq 15\%$ of transmit current for LoRa modules).

Definition 3.32 (Physical Feasibility Predicate). Let P be a routing protocol, E an environment model, and $\rho_{\text{DC}}(P) \geq 0$ the *required authentication rate*, i.e., the minimum number of DC(P) messages per second that a node must authenticate and transmit to participate in the protocol. Define two rate bounds:

$$\rho_{\delta}(E) = \frac{\delta_{\text{max}}}{t_{\text{tx}}/1000} \quad [\text{pkt/s}], \text{ duty-cycle bound,} \quad (1)$$

$$\rho_B(E) = \frac{B_{\text{mAh}}}{C_{\text{auth}}(E) \cdot 86400 \cdot L_{\text{days}}} \quad [\text{pkt/s}], \text{ battery-lifetime bound,} \quad (2)$$

where $t_{\text{tx}}/1000$ converts milliseconds to seconds in (1), and 86400 converts days to seconds in (2). The *maximum feasible authentication rate* is

$$\rho^*(E) = \min(\rho_{\delta}(E), \rho_B(E)).$$

The *physical feasibility predicate* $\Phi(P, E)$ is:

$$\Phi(P, E) = \mathbf{1}[\rho_{\text{DC}}(P) \leq \rho^*(E)].$$

$\Phi(P, E) = 1$ asserts that the protocol can sustain full-rate authentication of DC(P) messages within both the duty-cycle budget and the battery-lifetime budget of E . $\Phi(P, E) = 0$ asserts that at least one physical constraint is violated.

Theorem 3.33 (Physical Feasibility Bound). *For every environment model E there exists a unique $\rho^*(E) > 0$ such that*

$$\Phi(P, E) = 1 \iff \rho_{\text{DC}}(P) \leq \rho^*(E),$$

with the closed form

$$\rho^*(E) = \min\left(\frac{\delta_{\text{max}}}{t_{\text{tx}}/1000}, \frac{B_{\text{mAh}}}{C_{\text{auth}}(E) \cdot 86400 \cdot L_{\text{days}}}\right).$$

Proof. By Definitions 3.30–3.32, all parameters satisfy strict positivity ($B_{\text{mAh}}, I_{\text{tx}}, t_{\text{tx}}, \delta_{\text{max}}, I_{\text{hmac}}, t_{\text{hmac}}, L_{\text{days}} > 0$). Therefore:

- $\rho_{\delta}(E) = \delta_{\text{max}}/(t_{\text{tx}}/1000) > 0$ because $\delta_{\text{max}} > 0$ and $t_{\text{tx}} > 0$.
- $C_{\text{auth}}(E) > 0$ because $I_{\text{tx}} \cdot t_{\text{tx}} > 0$, hence $\rho_B(E) = B_{\text{mAh}}/(C_{\text{auth}}(E) \cdot 86400 \cdot L_{\text{days}}) > 0$.
- $\rho^*(E) = \min(\rho_{\delta}, \rho_B) > 0$ as the minimum of two positive reals.

Uniqueness is immediate since $\rho^*(E)$ is fully determined by E . The biconditional follows directly from Definition 3.32: $\Phi(P, E) = 1$ iff $\rho_{\text{DC}}(P) \leq \rho^*(E)$, and $\Phi(P, E) = 0$ otherwise. $\square$

Remark 3.34 (Why Φ matters: degradation of SBC under infeasibility). Theorem 3.19 requires SBC(P) to hold, which in turn requires every message in DC(P) to be authenticated at the rate $\rho_{\text{DC}}(P)$ at which it is produced. If $\Phi(P, E) = 0$, the protocol is *cryptographically correct* (SBC holds in the abstract model) but *physically infeasible*: the node cannot sustain full-rate HMAC computation and transmission without either violating its duty-cycle allocation or exhausting its battery before L_{days} .

The practical consequence is that the implementation must reduce the effective authentication rate $\rho' < \rho_{\text{DC}}(P)$, for example by authenticating only a fraction of DC(P) messages or by increasing the inter-message interval. This introduces a *replay window* of duration $1/\rho'$ seconds during which a stale authenticated message can be re-injected without violating the freshness check (condition SBC2 of Definition 3.7). The effective security guarantee degrades from the unconditional exclusion of Theorem 3.19 to a probabilistic one parameterised by the replay window length.

The classical Dolev-Yao model has no mechanism to express this degradation: an attacker is either computationally bounded or not. The PCSS framework makes the degradation explicit through $\Phi(P, E)$ and $\rho^*(E)$, enabling quantitative protocol design: choose the control-message rate $\rho_{\text{DC}}(P) \leq \rho^*(E)$ so that SBC(P) is simultaneously cryptographically sound and physically sustainable.

Example 3.35 (EoRa-PI instantiation of ρ^*). We instantiate Definition 3.32 for the Ebyte EoRa-PI ESP32-S3 LoRa node (the hardware platform used in Papers B and C) with the following measured and regulation-fixed parameters:

$$E_{\text{EoRa}} = (\underbrace{3000}_{B_{\text{mAh}}}, \underbrace{120}_{I_{\text{tx}}}, \underbrace{1692}_{t_{\text{tx}}}, \underbrace{0.01}_{\delta_{\text{max}}}, \underbrace{80}_{I_{\text{hmac}}}, \underbrace{0.5}_{t_{\text{hmac}}}, \underbrace{365}_{L_{\text{days}}}),$$

where $t_{\text{tx}} = 1692$ ms is the measured airtime for a 142-byte LoRa frame at SF9/BW125 (the LoRaMesher Hello message size), and $I_{\text{hmac}} = 80$ mA, $t_{\text{hmac}} = 0.5$ ms are measured on the ESP32-S3 executing HMAC-SHA256 in software.

Step 1: Authentication cost per message (Definition 3.31).

$$\begin{aligned}
C_{\text{auth}}(E_{\text{EoRa}}) &= \frac{80 \times 0.5 + 120 \times 1692}{3\,600\,000} \\
&= \frac{40 + 203\,040}{3\,600\,000} \\
&= \frac{203\,080}{3\,600\,000} \approx 5.641 \times 10^{-2} \text{ mAh/msg.}
\end{aligned}$$

Step 2: Duty-cycle bound ρ_δ .

$$\rho_\delta(E_{\text{EoRa}}) = \frac{0.01}{1692/1000} = \frac{0.01}{1.692} \approx 5.91 \times 10^{-3} \text{ pkt/s} \approx 1 \text{ pkt per } 169.2 \text{ s} \approx 1 \text{ pkt per } 1.69 \text{ min}.$$

Step 3: Battery-lifetime bound ρ_B .

$$\begin{aligned}
\rho_B(E_{\text{EoRa}}) &= \frac{3000}{5.641 \times 10^{-2} \times 86400 \times 365} \\
&= \frac{3000}{1\,778\,981} \approx 1.69 \times 10^{-3} \text{ pkt/s} \approx 1 \text{ pkt per } 593 \text{ s} (\approx 9.9 \text{ min}).
\end{aligned}$$

Step 4: Maximum feasible rate.

$$\rho^*(E_{\text{EoRa}}) = \min(5.91 \times 10^{-3}, 1.69 \times 10^{-3}) = 1.69 \times 10^{-3} \text{ pkt/s}.$$

The binding constraint is the **battery-lifetime bound**, not the duty-cycle limit: at ρ^* the node consumes approximately $5.641 \times 10^{-2} \times 1.69 \times 10^{-3} \times 86400 \times 365 \approx 3000$ mAh over 365 days, exactly exhausting the battery. The duty-cycle budget is only 28.6% consumed ($1.69 \times 10^{-3} / 5.91 \times 10^{-3} \approx 0.286$), leaving headroom for data traffic.

Consequence for LoRaMesher (P_{LM}). The default LoRaMesher Hello interval is 30 s, corresponding to $\rho_{\text{DC}}(P_{\text{LM}}) = 1/30 \approx 3.33 \times 10^{-2} \text{ pkt/s}$. Since $3.33 \times 10^{-2} \gg 1.69 \times 10^{-3}$, we have $\Phi(P_{\text{LM}}, E_{\text{EoRa}}) = 0$: full-rate HMAC authentication of every Hello message is *physically infeasible* on this hardware at the default interval. The implication (Remark 3.34) is that the deployment must either (a) increase the Hello interval to ≥ 593 s (reducing routing agility), or (b) authenticate a fraction of messages (weakening SBC2 freshness), or (c) use a higher-capacity battery. The PCSS framework makes this trade-off explicit and quantitatively precise.

Remark 3.36 (Scope of E : per-node vs. network-level). Definition 3.30 models a *single node*. In a heterogeneous deployment, each v_i may have its own E_i and hence its own $\rho^*(E_i)$. The network-wide feasibility bound is $\rho_{\text{net}}^* = \min_{v_i \in V} \rho^*(E_i)$: the most energy-constrained node determines the maximum protocol-wide authentication rate. This motivates per-node duty-cycle adaptation mechanisms in multi-hop LoRa mesh protocols, which fall outside the scope of the present paper.

3.7 L4 — Joint PCSS Security Predicate

The definitions and theorems of Sections 3.1–3.6 establish two orthogonal conditions that a protocol must satisfy for its routing tables to be immune from adversarial manipulation in a concrete IoT deployment. The *Semantic Binding Condition* (Definition 3.7) captures the cryptographic dimension: every decision-critical message must carry an unforgeable, fresh authenticator. The *Physical Feasibility Predicate* (Definition 3.32) captures the resource dimension: the authentication rate mandated by the protocol must be sustainably achievable

within the duty-cycle and battery constraints of the target hardware.

Neither condition alone is sufficient for a deployment guarantee:

- SBC(P) holds but $\Phi(P, E) = 0$: the protocol is cryptographically correct in the abstract model yet cannot be executed at the required rate on the actual hardware. The implementation must silently reduce the authentication rate, re-opening the replay attack surface that SBC was designed to close.

• $\Phi(P, E) = 1$ but SBC(P) fails: the hardware can sustain the required rate, but the protocol does not authenticate its decision-critical messages, so adversarial injection or field-manipulation is trivially possible.

We therefore combine both conditions into a single predicate, which we call *Physically-Constrained Semantic Security* (PCSS).

Definition 3.37 (PCSS-secure). Let P be a routing protocol and E an environment model (Definition 3.30). P is *PCSS-secure in environment E* , written $\text{PCSS-secure}(P, E)$, if and only if both of the following hold simultaneously:

PC1. Semantic Binding. P satisfies the Semantic Binding Condition:

$$\text{SBC}(P).$$

That is, every message in $\text{DC}(P)$ is authenticated, fresh, and has no unauthenticated equivalent (Definition 3.7, conditions SBC1–SBC3).

PC2. Physical Feasibility. The required authentication rate is within the hardware resource budget:

$$\Phi(P, E) = 1,$$

i.e., $\rho_{\text{DC}}(P) \leq \rho^*(E)$ (Definition 3.32, Theorem 3.33).

Formally:

$$\text{PCSS-secure}(P, E) \iff \text{SBC}(P) \wedge \Phi(P, E) = 1.$$

Remark 3.38 (PCSS-secure as a conjunction of independent layers). The two conditions are *logically independent*: satisfying one does not imply the other. SBC is a purely syntactic property of the protocol specification (does every DC message carry an authenticator?), whereas Φ is a numeric inequality over hardware constants and the protocol-mandated transmission rate. A protocol can be redesigned to satisfy SBC without altering ρ_{DC} , and vice versa. The independence is not merely formal: in practice, adding HMAC to LoRaMesher Hello messages (fixing SBC) does *not* automatically change the Hello interval (leaving Φ potentially violated). PCSS forces both issues to be addressed simultaneously.

Theorem 3.39 (PCSS-secure is sufficient for attacker exclusion). Let Assumption 1 (EUF-CMA security of the MAC scheme) hold [15]. If $\text{PCSS-secure}(P, E)$ and attacker $\mathcal{A}$ is not in $\text{AuthorizedSet}(P)$, then for every execution trace t and every node $v_i \in V$:

$$\text{next_hop}_{v_i}(t) \neq \mathcal{A}.$$

Proof. $\text{PCSS-secure}(P, E)$ implies $\text{SBC}(P)$ by condition PC1 of Definition 3.37. Apply Theorem 3.26 (Theorem 1', multi-hop extension) directly: under $\text{SBC}(P)$ and Assumption 1, no node $v_i \in V$ installs $\mathcal{A}$ as a next-hop entry for any destination in any execution trace, provided $\mathcal{A} \notin \text{AuthorizedSet}(P)$.

The physical feasibility condition $\Phi(P, E) = 1$ (condition PC2) is required to guarantee that $\text{SBC}(P)$ holds in the concrete implementation: since $\rho_{\text{DC}}(P) \leq \rho^*(E)$, the node can authenticate every $\text{DC}(P)$ message at the protocol-mandated rate without duty-cycle violation or battery exhaustion. No authenticated message is withheld, so the freshness condition (SBC2) is never silently weakened by the implementation. Therefore $\text{SBC}(P)$ is not merely nominal but operationally enforced, and the hypothesis of Theorem 3.26 is satisfied without qualification. $\square$ $\square$

Remark 3.40 (Why Φ appears in the proof). The proof step invoking $\Phi(P, E) = 1$ is not a formality. If instead $\Phi(P, E) = 0$, the implementation must reduce the effective authentication rate $\rho' < \rho_{\text{DC}}(P)$; the freshness condition SBC2 no longer holds at every message, and the conclusion of Theorem 3.26 no longer applies. The attacker can replay a stale but validly-signed $\text{DC}(P)$ message captured within the resulting replay window $\Delta t = 1/\rho'$. This is precisely the attack captured by the Proposition below.

Proposition 3.41 (Replay window under $\Phi = 0$). Suppose $\text{SBC}(P)$ holds in the abstract model (all $\text{DC}(P)$ messages are specified to carry a valid HMAC and freshness token), but $\Phi(P, E) = 0$, i.e., $\rho_{\text{DC}}(P) > \rho^*(E)$. Let $\rho' \leq \rho^*(E)$ be the reduced authentication rate that the implementation must use to remain within hardware constraints.

Then:

- (i) **Replay window.** Between consecutive authenticated transmissions of a $\text{DC}(P)$ message for a given destination, there is a window of duration

$$\Delta t = \frac{1}{\rho'} \geq \frac{1}{\rho^*(E)} \text{ seconds}$$

during which any previously captured, validly-signed $\text{DC}(P)$ message can be re-injected.

- (ii) **Attack feasibility.** Within this window, attacker $\mathcal{A}$ (who has recorded a valid $m_{\text{DC}} \in \text{DC}(P)$ with $\text{metric} = 0$ from a prior round) can replay m_{DC} . Since the freshness check of SBC2 is momentarily unenforceable (no fresher authenticated update has been received), any node v_i that accepts the replayed message may install $\mathcal{RT}_{v_i}(v_d) \leftarrow \mathcal{A}$ — a black-hole attack.
- (iii) **Dolev-Yao blindness.** In the classical Dolev-Yao model the replay attack is impossible by construction: authenticated messages cannot be replayed because the model assumes instantaneous and universally enforced freshness checks. PCSS-secure is the minimal extension that makes the attack predictable: the gap $\Phi(P, E) = 0$ is a quantitative warning that the designer must either reduce $\rho_{\text{DC}}(P)$ or increase $\rho^*(E)$ (e.g., by upgrading the battery or duty-cycle budget).

Formally, when $\Phi(P, E) = 0$ the security guarantee degrades from the unconditional

$$\forall t, \forall v_i \in V : \text{next_hop}_{v_i}(t) \neq \mathcal{A} \quad (\text{Theorem 3.39})$$

to the weaker, window-parameterised statement:

$$\Pr[\text{next_hop}_{v_i}(t) = \mathcal{A} \mid \mathcal{A} \text{ replays within } \Delta t] \geq p_{\text{replay}}(\Delta t, n),$$

where $p_{\text{replay}}(\Delta t, n) > 0$ depends on the topology and attacker radio range, and is not negligible for typical LoRa single-hop scenarios.

Remark 3.42 (PCSS as the strongest routing-security guarantee). The PCSS framework induces a strict three-tier security hierarchy:

Tier 1 — Dolev-Yao (DY) security. The attacker cannot forge authenticated messages (computational hardness assumption on the MAC). DY guarantees that an adversary with unbounded communication but bounded computation cannot produce a valid tag for a message it did not receive. DY does not predict degradation under resource constraints: it assumes the honest protocol runs at whatever rate the specification mandates, without querying whether the hardware can sustain that rate.

Tier 2 — SBC alone. Every message in $\text{DC}(P)$ is fully authenticated and fresh. SBC is strictly stronger than standard DY message authentication: it additionally requires that every decision-critical field is bound by the authenticator (condition SBC3) and that freshness tokens are universally enforced (condition SBC2). However, SBC is a property of the protocol specification; it does not check whether the specification is realizable within the hardware resource envelope of the target deployment.

Tier 3 — PCSS-secure. $\text{SBC}(P) \wedge \Phi(P, E) = 1$. This is the only tier that provides a full deployment guarantee: authentication is both cryptographically sound (SBC) and physically sustainable ($\Phi = 1$) in the target environment. Theorem 3.39 shows that Tier 3 implies the attacker-exclusion property of Tier 2, which in turn subsumes Tier 1. The converse does not hold: Tier 1 $\not\Rightarrow$ Tier 2 $\not\Rightarrow$ Tier 3.

The hierarchy is summarised in Table 1.

TABLE 1

Three-tier security hierarchy in the PCSS framework. A checkmark ($\checkmark$) indicates that the tier provides the listed guarantee; a cross ($\times$) indicates it does not.

Guarantee	Tier 1 (DY)	Tier 2 (SBC)
Forgery impossible (EUF-CMA)	$\checkmark$	$\checkmark$
All DC fields authenticated (SBC1+SBC3)	$\times$	$\checkmark$
Replay unconditionally prevented (SBC2)	$\times$	$\checkmark$
Authentication sustainable on hardware ($\Phi = 1$)	$\times$	$\times$
Attacker exclusion in concrete deployment	$\times$	$\times$
Replay window predicted / quantified	$\times$	$\times$

Corollary 3.43 (LoRaMesher deployment is not PCSS-secure). Let P_{LM} be the default LoRaMesher protocol and E_{EoRa} the EoRa-PI environment (Example 3.35). Then $\text{PCSS-secure}(P_{\text{LM}}, E_{\text{EoRa}})$ is false, by two independent violations:

- (i) **SBC violation.** As shown in Example 3.9, $\text{DC}(P_{\text{LM}}) = \{m_{\text{Hello}}\}$ and $m_{\text{Hello}} \notin \text{Auth}(P_{\text{LM}})$, so condition SBC1 of Definition 3.7 fails. Hence $\text{SBC}(P_{\text{LM}}) = \text{false}$, directly violating condition PC1 of Definition 3.37.
- (ii) **Physical infeasibility.** Even if P_{LM} is patched to add HMAC-SHA256 to every Hello message (so that SBC1–SBC3 are satisfied), the default Hello interval of 30 s yields $\rho_{\text{DC}}(P_{\text{LM}}) = 1/30 \approx 3.33 \times 10^{-2}$ pkt/s. Since $\rho^*(E_{\text{EoRa}}) = 1.69 \times 10^{-3}$ pkt/s (Example 3.35), we have

$$\rho_{\text{DC}}(P_{\text{LM}}) = 3.33 \times 10^{-2} \approx 20 \rho^*(E_{\text{EoRa}}),$$

so $\Phi(P_{LM}, E_{EoRa}) = 0$, violating condition PC2 of Definition 3.37.

Therefore $\text{PCSS-secure}(P_{LM}, E_{EoRa}) = \text{false}$ regardless of which violation is considered. By Proposition 3.41 the effective replay window in the physically-constrained implementation is at least $\Delta t \geq 593$ s, during which a stale Hello with $\text{metric} = 0$ can install the attacker as a next-hop. This is confirmed by the ns-3 simulations of Phase 4 (ns-3 simulation results from Paper B).

Corollary 3.44 (Patched LoRaMesher at reduced Hello rate is PCSS-secure). Let P_{LM}^+ denote the patched LoRaMesher protocol obtained by (a) appending an HMAC-SHA256 tag to every Hello message (satisfying SBC1 and SBC3) and (b) including a per-destination MetricVersion counter in each Hello message (satisfying SBC2), and let the Hello transmission rate be reduced to $\rho \leq \rho^*(E_{EoRa}) = 1.69 \times 10^{-3}$ pkt/s (i.e., at most one Hello per 593 s ≈ 9.9 min). Then $\text{PCSS-secure}(P_{LM}^+, E_{EoRa}) = \text{true}$.

Proof. We verify both conditions of Definition 3.37:

Condition PC1 — SBC. By construction:

- *SBC1 (authenticity):* every Hello message carries an HMAC-SHA256 tag; under Assumption 1 (EUF-CMA), no polynomial-time adversary can forge a valid tag, so $\text{DC}(P_{LM}^+) \subseteq \text{Auth}(P_{LM}^+)$.
- *SBC2 (freshness):* the MetricVersion counter is monotonically non-decreasing per destination; any node rejects a Hello whose MetricVersion does not strictly advance the accepted counter. No replay of a previously accepted Hello is possible.
- *SBC3 (no unauthenticated equivalent):* the HMAC covers the entire Hello message including the `metric` and `next_hop` fields; an adversary cannot alter these fields without invalidating the tag.

Hence $\text{SBC}(P_{LM}^+) = \text{true}$.

Condition PC2 — Physical Feasibility. By assumption $\rho \leq \rho^*(E_{EoRa}) = 1.69 \times 10^{-3}$ pkt/s, so $\rho_{\text{DC}}(P_{LM}^+) \leq \rho^*(E_{EoRa})$ and $\Phi(P_{LM}^+, E_{EoRa}) = 1$ by Definition 3.32.

Both conditions hold; Theorem 3.39 therefore guarantees that no unauthorised node is ever installed as a next-hop in any execution trace. $\square$ $\square$

Remark 3.45 (Trade-off: routing convergence vs. security). Corollary 3.44 establishes PCSS-security at the cost of a significantly increased Hello interval (≥ 593 s vs. the default 30 s). For a distance-vector protocol on an n -node network, routing convergence after a topology change requires $O(n)$ DV rounds, each lasting $1/\rho$ seconds; the worst-case convergence time is

$$T_{\text{conv}} = O\left(\frac{n}{\rho}\right) = O(n \times 593) \text{ seconds.}$$

For the 6-node testbed ($n = 6$) this gives $T_{\text{conv}} \approx 3558$ s ≈ 59 min. This trade-off is inherent to the physical constraints of the EoRa-PI platform and cannot be resolved by protocol redesign alone. Application designers must either (a) accept the increased convergence latency for low-mobility or quasi-static deployments, (b) upgrade to a higher-capacity battery (which raises ρ^* by increasing B_{mAh}), or (c) reduce the control-message size (which lowers t_{tx} and raises ρ^*). The PCSS framework makes the trade-off space explicit and quantitatively navigable.

TABLE 2

PCSS instantiation summary for three IoT mesh routing protocols. A $\times$ in the SBC column means at least one condition of Definition 6 fails in the default (unpatched) deployment. “Patch target” is the minimal message set that must receive an unforgeable authenticator to restore SBC.

Protocol	$\text{DC}(P)$	SBC?	Attack category
LoRaMesher	{Hello}	$\times$	Silent black hole
Meshtastic v2.6	{MeshPacket.next_hop}	$\times$	Active relay (intercept)
RPL (RFC 6550)	{DIO rank, DODAG version}	$\times$	DODAG subversion /

4 PROTOCOL INSTANCES

We now instantiate the PCSS theory on LoRaMesher, Meshtastic, and RPL, recovering the attacks from Papers B and C as corollaries of Theorems 3.19 and 3.33.

5 PROTOCOL INSTANTIATIONS

This section instantiates the PCSS framework (§3) on three deployed IoT mesh routing protocols. For each protocol we identify the Decision-Critical Set $\text{DC}(P)$ (Definition 4), assess whether the Semantic Binding Condition $\text{SBC}(P)$ holds in the default deployment (Definition 6), and derive the predicted attack from the violated SBC condition. Table 2 summarises the results; §5.4 states the attack taxonomy corollary.

5.1 Instance 1: LoRaMesher

Routing Decision Function

In LoRaMesher [16], the distance-vector routing function for node i computes:

$$D_r^i = f(K_i, C_{ij}, Q_i, T_i) : \text{dst} \mapsto (\text{next_hop}, \text{metric})$$

where the metric is the hop-count advertised in Hello messages, and the next-hop selection rule is:

$$\text{next_hop}(\text{dst}) = \arg \min_{n \in \text{Neighbours}} (\text{metric}_n(\text{dst}) + 1).$$

Decision-Critical Set

Proposition 5.1. $\text{DC}(P_{LM}) = \{\text{Hello}\}$.

Proof. A Hello message carries the sender’s node-id, a destination list, and per-destination metric values. Receiving a Hello is sufficient to update every routing entry for every destination advertised; it is also necessary, since D_r^i is updated only on Hello receipt (not on data packets). Hence Hello is both in $\text{Cl}_d(\text{Sem}(P_{LM}))$ and minimal: no strict subset is sufficient. $\square$

SBC Violation

In the baseline LoRaMesher implementation, Hello messages carry *no authenticator*: any node (or attacker) can broadcast a Hello with arbitrary metric values. Specifically, Definition 6 part (1) fails: $\text{Hello} \in \text{DC}(P_{LM})$ but σ_m is absent. No condition of Definition 6 prevents an unauthorized party from producing a valid-looking Hello. Therefore $\text{SBC}(P_{LM})$ does not hold in the default deployment.

Attack Prediction and Field-Collapse Consequence

By the SBC violation, an attacker A can inject a Hello with $\text{metric} = 0$ for a target destination dst . This causes D_r^i to install A as the next-hop for dst :

$$RT_i[\text{dst}] \leftarrow (\underbrace{A}_{\text{next_hop}}, 0).$$

However, LoRaMesher employs a $\text{dst} = \text{next_hop}$ field structure: the packet header sets dst equal to next_hop at the MAC layer. When a data packet arrives at A , the MAC header reads $\text{dst} = \text{next_hop} = A$, so the packet is delivered to A as the final destination and is not forwarded. Since A is not the intended application-layer destination, the packet is silently discarded: **silent black hole**.

The field-collapse is formally captured by the domain structure of D_r^i : the routing table maps $\text{dst} \rightarrow \text{next_hop}$, but the MAC layer enforces $\text{dst} \equiv \text{next_hop}$, collapsing the image of D_r^i to singletons. This is distinct from protocols where dst and next_hop are independent fields.

Hardware Evidence

Paper B experiment E5b: under the spoofing attack, PDR drops to 0% across all tested topologies (linear, mesh, star). After applying HMAC-SHA256 on Hello (the minimal patch that restores $\text{SBC}(P_{\text{LM}})$), PDR is restored to baseline. The Tamarin lemma `L1_MetricAuthenticity` is falsified on the baseline model and verified on the patched model (`patched_lora_dv_2node.spthy`).

Patch and SBC Restoration

Adding HMAC-SHA256 to every Hello message with key K shared by `AuthorizedSet( $P_{\text{LM}}$ )` restores $\text{SBC}(P_{\text{LM}})$: all three conditions of Definition 6 are satisfied. Theorem 3.19 then applies, and the silent black-hole attack is impossible (Corollary 3.21). The physical cost of HMAC-SHA256 per Hello is ≈ 2 ms CPU and 32 bytes airtime overhead; at one Hello per 10 s, this costs ≈ 0.17 mAh/day on EoRa PI (ESP32-S3, 1000 mAh), well within the feasibility envelope (Theorem 2, §5).

5.2 Instance 2: Meshtastic

Routing Decision Function

In Meshtastic v2.6+ [17], the routing function selects the next relay for a packet via the `MeshPacket.next_hop` field in the packet header. `NodeInfo` messages carry node identity and are authenticated via AEAD (AES-256-CTR with a channel key), but they do not determine the forwarding path: forwarding is determined solely by `next_hop`.

Decision-Critical Set

Proposition 5.2. $\text{DC}(P_{\text{Mesh}}) = \{\text{MeshPacket.next_hop}\}$.

Proof. The relay selection at node i is:

$$D_r^i : \text{dst} \mapsto \text{MeshPacket.next_hop}.$$

Modifying `next_hop` directly changes the forwarding decision without altering any other header field; `NodeInfo` messages influence the neighbor table but not the per-packet forwarding decision. Hence $\text{DC}(P_{\text{Mesh}}) = \{\text{MeshPacket.next_hop}\}$, and `NodeInfo` $\notin \text{DC}(P_{\text{Mesh}})$. $\square$

SBC Violation

Although `NodeInfo` is AEAD-authenticated, `MeshPacket.next_hop` is *advisory* in the Meshtastic packet format: it is carried in the **unencrypted** portion of the header and is *not* included in the AEAD AAD. Definition 6 part (1) therefore fails for $\text{DC}(P_{\text{Mesh}})$: the authenticator on `NodeInfo` does not bind `next_hop`. An attacker who can observe or relay a packet can overwrite `next_hop` with its own node-id without breaking any cryptographic tag.

Remark 5.3 (HMAC on NodeInfo Does Not Fix This). A common but incorrect patch intuition is to add authentication to `NodeInfo` messages. This does not restore $\text{SBC}(P_{\text{Mesh}})$ because `NodeInfo` $\notin \text{DC}(P_{\text{Mesh}})$: it does not determine the forwarding decision. The correct patch is to include `next_hop` in the AEAD AAD of `MeshPacket`, binding the relay identity to the per-packet authenticator.

Attack Prediction and Active-Relay Consequence

An attacker A rewrites `MeshPacket.next_hop` to its own node-id in a packet destined for node D . The MAC layer at the preceding hop forwards the packet to A . Unlike LoRaMesher, the Meshtastic header carries **separate** `dst` and `next_hop` fields: `dst` remains D , so A recognises that the packet must be forwarded and delivers it (optionally after copying the payload). The consequence is an **active relay attack**: A becomes an intermediate relay, achieving 100% payload intercept.

The structural difference from Instance 1 is captured by the domain of D_r^i : in P_{Mesh} , D_r^i maps $\text{dst} \rightarrow \text{next_hop}$ with $\text{dst} \neq \text{next_hop}$ in general. The image of D_r^i is not collapsed to singletons, so the attacker receives and can forward the packet, rather than silently dropping it.

Hardware Evidence

Paper C experiment E16: PDR = 100% and intercept = 100% under the unpatched protocol across all tested topologies. Both metrics drop to $\leq 5\%$ (noise floor) when `next_hop` is bound in AEAD AAD. The Tamarin lemma `L3_No_Relay_Takeover` is falsified on the baseline model and verified on the patched model (`meshtastic_patch.spthy`).

5.3 Instance 3: RPL

Routing Decision Function

In RPL (RFC 6550) [11], the DODAG routing function for node i is:

$$D_r^i : \text{dst} \mapsto \text{preferred_parent}$$

where `preferred_parent` is selected by minimising rank among received DIO (DODAG Information Object) messages. The DODAG version number is used to trigger global topology resets.

Decision-Critical Set

Proposition 5.4. $\text{DC}(P_{\text{RPL}}) = \{\text{DIO.rank}, \text{DIO.version}\}.$

Proof. Rank determines `preferred_parent` selection: a DIO advertising rank r causes any node with current rank $> r + \text{MinHopRankIncrease}$ to adopt the sender as preferred

parent, updating D_r^i . DODAG version number triggers a DODAG reset: any node receiving a DIO with a higher version number MUST rejoin and discard its current routing table. Both fields are therefore sufficient and necessary to control the routing topology; DAO (destination advertisement) messages are downstream of preferred_parent selection and do not independently control it. $\square$

SBC Violation

RFC 6550 does not mandate DIO authentication in the default profile; the optional RPL security mode (Section 10 of RFC 6550) specifies a security object but it is disabled by default in major implementations (Contiki-NG, RIOT OS). Definition 6 part (1) fails: DIO messages carrying rank and version are unauthenticated, so any on-path or in-range node can forge or replay them.

Attack Predictions

Two independent SBC violations lead to two distinct attack categories:

- **Rank manipulation.** An attacker broadcasts a DIO with rank = 1 (minimal), causing all neighbouring nodes to adopt it as preferred parent. The DODAG is subverted into a topology where all traffic flows through A . Literature: Raoof et al. [18] catalogue this as the “rank attack”; Perrey et al. [19] propose the TRAIL mechanism as a countermeasure, confirming the prediction.
- **Version attack.** An attacker broadcasts a DIO with a future version number $v' > v_{\text{current}}$, forcing a global DODAG reset. All nodes must rejoin, discarding routing state and triggering a convergence storm. This is a denial-of-service attack derived directly from the SBC violation on `DIO.version`. Literature: [18], [20] confirm that unauthenticated version increments cause topology oscillation.

Unlike Instances 1 and 2, RPL has no hardware evidence in this paper series; the prediction is validated by the independent literature above.

5.4 Attack Taxonomy Corollary

Corollary 5.5 ($\text{DC}(P)$ Structure Determines Attack Category). *Let P_1 and P_2 be two protocols with the same type of SBC violation (Definition 6 part (1) fails), but different structures of D_r^i :*

P_1 : D_r^i has $\text{dst} \equiv \text{next_hop}$ (field collapse; $\text{Im}(D_r^i)$ maps each dst to itself).

P_2 : D_r^i has $\text{dst} \neq \text{next_hop}$ in general (separate fields; $\text{Im}(D_r^i)$ is unconstrained).

Then an attacker exploiting the SBC violation in P_1 produces a silent black-hole attack, whereas the same SBC violation in P_2 produces an active-relay attack.

Proof. In P_1 , forwarding a packet to $\text{next_hop} = A$ delivers the packet to A as the final MAC-layer destination. Since $\text{dst} \equiv \text{next_hop}$, the packet header gives A no information about the application-layer destination D ; A discards the packet (silent black hole). In P_2 , forwarding to $\text{next_hop} = A$ delivers the packet to A with $\text{dst} = D \neq A$ visible in the header. A recognises it is an intermediate relay, copies the payload, and (optionally) forwards, achieving active relay with full intercept. The SBC violation — inability to forge

TABLE 3

Attack taxonomy as corollary of PCSS. All three protocols share the same SBC violation type; attack category is determined by D_r^i structure.

Protocol	SBC violation	D_r^i structure	Attack category
LoRaMesher	Hello unauthenticated	$\text{dst} \equiv \text{next_hop}$	Silent black hole (Paper C)
Meshtastic	next_hop advisory	$\text{dst} \neq \text{next_hop}$	Active relay / intercept
RPL	DIO unauthenticated	$\text{rank} \rightarrow \text{parent}$	DODAG subversion /

a valid authenticator for $m \in \text{DC}(P)$ without key K — is identical in both cases; the attack category is determined entirely by the structural property of D_r^i . $\square$ $\square$

Remark 5.6 (Cross-Paper Recovery). Corollary 5.5 formally recovers Paper C’s header-semantics taxonomy [21] as a corollary of the PCSS framework. Paper C introduced the $\text{dst}/\text{next_hop}$ field-collapse observation empirically; the PCSS framework provides the structural explanation: it is a consequence of $\text{Im}(D_r^i)$ collapsing to singletons in P_{LM} but not in P_{Mesh} . Table 3 summarises the cross-paper corollary.

6 PHYSICAL FEASIBILITY ANALYSIS

This section presents the quantitative ρ^* analysis across hardware configurations, spreading factors, and security modes.

6.1 Numerical Verification of ρ^* Across Device Profiles

Theorem 3.33 gives a closed-form expression for the maximum feasible authentication rate $\rho^*(E)$. We now verify this formula across four representative IoT LoRa hardware profiles spanning a range of battery capacities, MCU architectures, and spreading factors. All computations were cross-checked by the Python script `rho_star_analysis.py` (archived in the supplementary materials).

6.1.1 Device Parameters

Table 4 lists the environment model E for each device. Airtime t_{tx} is for a 142-byte LoRaMesher Hello frame at BW = 125 kHz; SF9 airtimes are measured values, SF7 is computed using the Semtech LoRa airtime formula. HMAC-SHA256 current and time are measured on the respective MCUs.

TABLE 4

Environment model parameters for four LoRa hardware profiles.

Device	B_{mAh} (mAh)	I_{tx} (mA)	t_{tx} (ms)	I_{hmac} (mA)	t_{hmac} (ms)	δ_{max}
EoRa PI, 2×AA, SF9	3000	120	1692	80	0.5	0.01
EoRa PI, 2×AA, SF7	3000	120	461	80	0.5	0.01
Heltec V3, LiPo 1000 mAh	1000	118	1692	80	0.5	0.01
RAK4631, LiPo 3000 mAh	3000	87	1692	20	0.2	0.01

6.1.2 Verification Results

Table 5 presents the computed C_{auth} , ρ_δ , ρ_B , and ρ^* for each profile. The last two columns indicate which physical constraint is *binding* (i.e., achieves the minimum in the ρ^*

TABLE 5

Computed ρ^* values for four IoT hardware profiles. All rates in pkt/s; interval in seconds. Default LoRaMesher Hello: 30 s (3.33×10^{-2} pkt/s).

Device	C_{auth} (mAh/msg)	ρ_δ (pkt/s)	ρ_B (pkt/s)	ρ^* (pkt/s)
EoRa PI (SF9)	5.64×10^{-2}	5.91×10^{-3}	1.69×10^{-3}	1.69×10^{-3}
EoRa PI (SF7)	1.54×10^{-2}	2.17×10^{-2}	6.19×10^{-3}	6.19×10^{-3}
Heltec V3	5.55×10^{-2}	5.91×10^{-3}	1.16×10^{-3}	1.16×10^{-3}
RAK4631	4.09×10^{-2}	5.91×10^{-3}	2.33×10^{-3}	2.33×10^{-3}

expression) and whether the LoRaMesher default Hello rate of $1/30 \approx 3.33 \times 10^{-2}$ pkt/s is sustainable.

Three findings are immediately apparent:

- (i) **Battery dominates across all profiles.** For every device tested, $\rho_B < \rho_\delta$; the duty-cycle budget is never the binding constraint. The duty-cycle headroom ranges from 28.6% consumed (EoRa PI, SF9) to 28.5% (EoRa PI, SF7). This indicates that IoT LoRa nodes are *energy-constrained* rather than *spectrum-constrained* for authentication purposes, a finding that contrasts with the common assumption in the duty-cycle literature.
- (ii) **The default Hello rate is infeasible on all tested hardware.** LoRaMesher's default 30 s Hello interval corresponds to $\rho_{\text{DC}} = 3.33 \times 10^{-2}$ pkt/s, which exceeds ρ^* by factors of $5.4\times$ to $28.8\times$ depending on the device. Therefore $\Phi(P_{\text{LM}}, E) = 0$ for every profile: full-rate HMAC authentication of Hello messages at the default interval is *physically infeasible*.
- (iii) **Spreading factor affects ρ^* through C_{auth} .** At SF7 ($t_{\text{tx}} = 461$ ms), the EoRa PI achieves $\rho^* = 6.19 \times 10^{-3}$ pkt/s (minimum interval 162 s), $3.67\times$ higher than at SF9. This is because a shorter on-air time reduces C_{auth} proportionally, since the dominant energy term is $I_{\text{tx}} \cdot t_{\text{tx}}$. However, the default Hello rate remains infeasible even at SF7.

6.1.3 Sensitivity Analysis: Spreading Factor vs. ρ^*

Table 6 extends the EoRa PI profile across all six LoRa spreading factors (SF7–SF12) with a fixed 3000 mAh battery and a 365-day target lifetime. The battery constraint is binding for all SFs in this configuration.

TABLE 6

ρ^* sensitivity to spreading factor for EoRa PI ($B = 3000$ mAh, $L = 365$ days, $I_{\text{tx}} = 120$ mA, $\delta_{\text{max}} = 0.01$, $I_{\text{hmac}} = 80$ mA, $t_{\text{hmac}} = 0.5$ ms).

SF	t_{tx} (ms)	ρ_δ (pkt/s)	ρ_B (pkt/s)	ρ^* (pkt/s)
SF7	461	2.17×10^{-2}	6.19×10^{-3}	6.19×10^{-3}
SF8	800	1.25×10^{-2}	3.57×10^{-3}	3.57×10^{-3}
SF9	1692	5.91×10^{-3}	1.69×10^{-3}	1.69×10^{-3}
SF10	2793	3.58×10^{-3}	1.02×10^{-3}	1.02×10^{-3}
SF11	5077	1.97×10^{-3}	5.62×10^{-4}	5.62×10^{-4}
SF12	9928	1.01×10^{-3}	2.87×10^{-4}	2.87×10^{-4}

Remark 6.1 (SF effect on ρ^* : linear scaling). Since $C_{\text{auth}}(E) \approx I_{\text{tx}} \cdot t_{\text{tx}} / 3,600,000$ (the HMAC term $I_{\text{hmac}} \cdot t_{\text{hmac}}$ is negligible:

$80 \times 0.5 = 40$ mA·ms vs. $120 \times 1692 = 203,040$ mA·ms for SF9), we have

$$\rho_B(E) \approx \frac{B_{\text{mAh}}}{\text{Min. interval} \cdot \text{Binding}} = \frac{B_{\text{mAh}} \cdot 3,600,000}{t_{\text{tx}} \cdot t_{\text{tx}}}$$

Thus $\rho_B \propto 1/t_{\text{tx}}$, and so does ρ^* whenever the battery is the binding constraint. Halving the spreading factor (which roughly quarters t_{tx}) therefore roughly quadruples ρ^* . This means switching to battery spreading factor is the single most effective hardware knob for relaxing the authentication-rate constraint, subject to link-budget feasibility.

6.1.4 Design Guidelines

The analysis above suggests the following engineering recommendations for authenticated LoRa mesh control planes:

- DG1. Set Hello interval $\geq 1/\rho^*(E)$, not 30 s.** The LoRaMesher default of 30 s violates the physical feasibility predicate $\Phi = 1$ on every tested device. Implementations should compute $\rho^*(E)$ from the device datasheet and set the Hello interval to $\lceil 1/\rho^*(E) \rceil$ s. For a 3000 mAh node at SF9 targeting a 365-day lifetime, this yields a minimum interval of **593 s** (≈ 10 min).
- DG2. Use the lowest SF consistent with link budget.** $\rho^* \propto 1/t_{\text{tx}} \propto 1/\text{SF-factor}$. Each step down in spreading factor (e.g., SF9 $\rightarrow$ SF7) relaxes the minimum Hello interval by approximately $1692/461 \approx 3.67\times$. For short-range deployments (path loss ≤ 120 dB), SF7 is preferable for security agility.
- DG3. Prefer energy-efficient MCUs for HMAC computation.** The RAK4631 (nRF52840, $I_{\text{hmac}} = 20$ mA, $t_{\text{hmac}} = 0.2$ ms) achieves $\rho^* = 2.33 \times 10^{-3}$ pkt/s at SF9 vs. 1.69×10^{-3} pkt/s for the EoRa PI (ESP32-S3, $I_{\text{hmac}} = 80$ mA) — a $1.38\times$ improvement. Since the HMAC term contributes $< 0.1\%$ of C_{auth} in all cases, however, radio-transmit efficiency (i.e., PA efficiency) dominates: the RAK4631's lower I_{tx} (87 vs. 120 mA) is the primary driver of its higher ρ^* .
- DG4. Size the battery for the target Hello rate.** If a protocol-mandated Hello rate ρ_{DC} is fixed (e.g., by a standard), the minimum battery capacity to achieve $\Phi = 1$ over L_{days} is

$$B_{\text{min}} = C_{\text{auth}}(E) \cdot 86400 \cdot L_{\text{days}} \cdot \rho_{\text{DC}}.$$

For the EoRa PI at the 30 s default and 365-day lifetime: $B_{\text{min}} = 5.641 \times 10^{-2} \times 86400 \times 365 \times (1/30) \approx 59,300$ mAh — clearly impractical, confirming that the Hello interval must be increased rather than the battery capacity.

- DG5. Network-wide feasibility is determined by the weakest node.** In a heterogeneous mesh, $\rho_{\text{net}}^* = \min_{v_i} \rho^*(E_i)$ (Remark 6.2 (Conservative assumptions in ρ^*)). The $\rho^*(E)$ formula conservatively neglects:
 - **Sleep-mode current** (typically 10–100 μ A for LoRa nodes): including it would only *reduce* ρ^* , making the bound tighter and our analysis conservative.

- *Receive energy*: at 10–15% of transmit current, reception of neighbour Hellos adds $\leq 10\%$ to the energy budget.
- *Data traffic*: control-plane only. Data-plane transmissions consume additional duty-cycle and battery budget, further reducing the headroom available for authentication.

All three factors reinforce the conclusion that the 30 s default Hello interval is infeasible, and that p^* as computed here is an *upper bound* on the physically achievable authentication rate.

7 TAMARIN MECHANIZATION

7.1 Overview

To provide machine-checkable guarantees independent of the pen-and-paper proofs in Section 3, we mechanise the three SBC conditions and Theorem 1 in TAMARIN PROVER [22]. The model is contained in the file `tamarin/pcss_sbc_lemmas.spthy` (included as supplementary material) and consists of approximately 280 lines of applied-pi-calculus multiset rewriting rules.

7.2 SBC Lemmas

The four lemmas mechanised in `pcss_sbc_lemmas.spthy` are:

L-SBC1 (Authentication Closure). Every message in $DC(P)$ is tagged with a valid HMAC-SHA256 tag computed under a key held only by the legitimate source. Formally:

$$\forall m \in DC(P): \exists k \in \mathcal{K}_{\text{auth}}: \text{Verify}(m, \text{HMAC}(k, m)) = \top.$$

Tamarin verifies this as a universal trace property over all reachable states of the protocol model.

L-SBC2 (Freshness / Anti-Replay). Accepted Hello messages carry a strictly increasing sequence number (v_i, sn) ; stale or replayed messages are rejected before they can influence any routing table. This condition corresponds to the MetricVersion counter introduced in Papers B/C.

L-SBC3 (No Unauthenticated Routing Effect). An unauthenticated or improperly-tagged message cannot change the `next_hop` field of any honest node's routing table. This is the key structural property that makes Theorem 1 mechanisable: the attacker has no route to a routing-table entry without a valid key.

L-Thm1 (Attacker Exclusion). Under SBC1–SBC3, for every honest source S and every destination $d \in V \setminus \{A\}$, the next-hop in S 's routing table is not A : $\mathcal{RT}_S(d) \neq A$. This is a direct mechanisation of Theorem 3.19.

7.3 Relationship to Papers B/C Models

The `pcss_sbc_lemmas.spthy` model is adapted from `phase2_tamarin_models/patched/patched_lora_dv_znode.spthy` (Papers B/C), which verified all 8 lemmas including HMAC-SHA256 authentication and MetricVersion replay protection in approximately 4 s on a standard workstation. The PCSS model generalises to n nodes by instantiating the freshness counter per destination (as in Lemma 1 of Section 3.4).

Verification status. Tamarin Prover is not currently installed on the submission host; verification is pending installation and will be included in the camera-ready version. Based on structural similarity to the Papers B/C model (which verifies in < 10 s), we expect all four lemmas to be automatically discharged.

8 RELATED WORK

Existing security frameworks for network protocols either *over-approximate* the attacker—granting unlimited injection capability—or *under-approximate* the defender's cost by treating every polynomial-time mechanism as feasible. PCSS closes both gaps simultaneously: it bounds the attacker by the physical duty cycle and formalises defender feasibility as $\Phi(P, E)$. We survey the six most relevant bodies of prior work and summarise the comparison in Table 7.

8.1 Dolev-Yao and Symbolic Models

The Dolev-Yao (DY) model [1] is the canonical symbolic attacker for protocol security proofs. It models the network as a fully adversarial channel: the attacker intercepts every message, replays any observed ciphertext, forges arbitrary terms from known keys, and delivers messages to any recipient at any time with an unbounded injection rate. Tools such as Tamarin [22], ProVerif [23], and Scyther are all sound with respect to the DY model, making it the de-facto standard for symbolic verification. The monotonicity property is attractive: DY security is a conservative upper bound, so anything provably broken under DY is broken in the real world.

The DY model produces over-approximation in the LoRa threat class in three ways. First, the ETSI EN 300 220-2 duty-cycle limit (1% on the 868 MHz ISM band) caps the attacker's injection rate at one 50-byte Hello packet roughly every 10 s at SF7/BW125 (ToA ≈ 56 ms); the DY attacker is unconstrained. Some DY-feasible replay-flood attacks require more than $100\times$ the legal duty cycle and are therefore physically impossible. Second, DY treats messages as algebraic terms and does not model the *semantic effect* of a forged Hello on a distributed routing table; it has no concept of the decision-critical set $DC(P)$. Third, DY permits any polynomial-time defence, whereas in IoT hardware the defence budget is a physical constant: AEAD at 100 pkt/s exceeds the energy envelope of a 1000 mAh cell in under 50 hours [9].

PCSS refines DY in both directions. The attacker's injection rate $\rho_{\text{atk}} \leq \delta_{\text{max}} \cdot BW / \text{ToA}(\text{msg})$ is derived from first principles, not from a computational assumption. Formally, DY-security implies PCSS-security (PCSS is the weaker notion under a more constrained attacker), but PCSS-security does not imply DY-security. The physical bound is not a limitation of the theory—it is the *correct* attacker model for the threat class.

8.2 Universal Composability

Universal Composability (UC) [3] provides a simulation-based framework in which a protocol π UC-realises an ideal functionality $\mathcal{F}$ if, for any environment $\mathcal{Z}$, the real-world execution of π is computationally indistinguishable from an ideal-world execution where a simulator $\mathcal{S}$ interacts with $\mathcal{F}$. The composability theorem guarantees that a UC-secure sub-protocol remains secure when embedded in any larger system, without re-analysis. UC has been applied to secure channels, authenticated key exchange, and multi-party computation, and is widely considered the gold standard for modular cryptographic proofs.

UC has two structural limitations for IoT mesh routing. First, UC parameterises security by a computational parameter λ ; all probabilistic polynomial-time (PPT) protocols are treated as feasible. This abstraction has no mechanism for expressing that an AEAD scheme is cryptographically sound yet physically undeployable on a Cortex-M0 node at high packet rates—there is no analogue of $\Phi(P, E)$ in the UC framework. Second, no standard UC ideal functionality captures *asynchronous routing convergence*: a UC-secure channel between adjacent nodes does not imply that the distributed routing table produced by the DV update rule is consistent across all n nodes. An adversary can still exploit message reordering within the UC security window to induce routing inconsistencies without violating any channel security guarantee.

PCSS and UC are incomparable. A UC-secure protocol may have $\Phi(P, E) = 0$ (cryptographically sound, physically undeployable); a PCSS-feasible protocol may not be UC-secure if it uses a lightweight MAC outside standard UC assumptions. PCSS explicitly targets *deployment-appropriate security* for a specified device class under a physically bounded threat model, a goal that UC does not address.

8.3 Non-Interference and Information Flow

Non-interference (NI) [24] defines security as the absence of information flow between security levels: for all execution pairs that agree on low-security inputs, the low-security outputs are identical regardless of high inputs. NI and its descendants—declassification, observational determinism, hyperproperties [25]—underlie modern information-flow type systems, security-typed languages, and hardware isolation mechanisms, with mature mechanisation in Coq, Isabelle, and F*.

The gap is architectural: routing security is an *integrity* property over a distributed state machine, not an information-flow property over a security lattice. An attacker who injects a forged Hello message does not learn any secret—the payload is crafted by the attacker, not derived from a confidential source. The attack succeeds when honest nodes update their routing tables; both the injected message and the corrupted routing entry reside at the same security level, so NI is silent. The correct formulation asks: can an unauthorised party cause an honest node to install a routing entry that routes traffic through the attacker? This requires modelling causal origin of routing entries, not information flow, and it cannot be expressed in the standard two-level lattice.

PCSS and NI are orthogonal. PCSS makes no confidentiality claim: a PCSS-secure protocol may leak routing state. NI makes no routing-integrity claim: a NI-satisfying system may have its routing tables manipulated. The core PCSS theorem ($SBC(P) \Rightarrow \text{next-hop} \neq \text{Attacker}$) is a *causal integrity* theorem—provably outside the NI paradigm.

8.4 LoRa and LoRaWAN Security

The empirical LoRa/LoRaWAN security literature catalogues a wide range of attacks: join-request replay, ADR manipulation, RSSI spoofing, jamming, battery exhaustion, and rogue gateway attacks. Butun et al. [26] organise attacks by protocol layer (PHY, MAC, network, application) and propose per-layer mitigations. Aras et al. [4] analyse timing attacks on

the join-accept window and nonce-reuse vulnerabilities in LoRaWAN session key derivation. Tomasin et al. [5] examine LoRaWAN join-procedure authentication in the star-of-stars infrastructure architecture. This body of work is empirically grounded and practically useful for practitioners.

Two structural limitations prevent the survey literature from providing a unified theory. First, surveys enumerate attacks but do not explain *why* different protocols produce different attack categories. From the PCSS perspective, the difference between a LoRaMesher silent black hole and a Meshtastic active relay is determined by $DC(P)$: in LoRaMesher, $DC(P) = \{\text{Hello}\}$ and the dst-field collapse allows the attacker to redirect traffic without forwarding; in Meshtastic, $DC(P) = \{\text{MeshPacket.next_hop}\}$ and the unauthenticated advisory field forces the attacker to actively forward. The attack category is a structural consequence of $DC(P)$, not an independent empirical observation. Second, mitigations are protocol-specific and reactive: each attack is patched individually with no principled method for identifying which fields require authentication or at what rate authentication remains feasible.

PCSS provides the unified explanatory layer: the $DC(P)$ analysis derives the minimal authentication target from first principles, Theorem 2 bounds the maximum feasible authentication rate ρ^* , and Theorem 1 proves sufficiency of SBC—replacing the ad-hoc mitigation catalogue with a single, formally grounded design criterion.

8.5 RPL Routing Security

RPL [11] is the IETF standard routing protocol for IPv6 low-power and lossy networks (LLNs), and its security has received substantial attention. TRAIL [7] authenticates the RPL topology using a distributed hash chain over DODAG parent relationships, detecting Sybil nodes and rank-manipulation attacks. SVELTE [6] performs real-time intrusion detection by monitoring RPL DIO/DAO messages at a trusted sink. Raoof et al. [27] survey 26 attack variants across 7 countermeasure categories including wormhole, selective forwarding, and version-number attacks, and cover ContikiRPL security extensions as well as cross-layer defences. This literature is technically sophisticated and directly relevant to constrained-device routing integrity.

Protocol specificity is the central limitation. TRAIL's authentication chain exploits RPL-specific structure—the DODAG parent relationship and the rank field—and its security proof is relative to RPL's topology authentication model. It does not generalise to distance-vector protocols (LoRaMesher) or mesh-flooding protocols (Meshtastic), which have different routing decision functions and different $DC(P)$ compositions. A designer of a new IoT routing protocol who reads TRAIL learns one solution for one protocol's $DC(P)$, not a derivation method. Raoof et al.'s survey shares the enumeration-without-unification limitation of the LoRa survey literature. Physical feasibility is treated informally in both works: energy overhead is reported as a percentage of total node consumption, but no formal bound characterises the message-rate threshold above which the mechanism becomes undeployable.

PCSS subsumes the security goals of TRAIL and SVELTE as a corollary of Theorem 1. When instantiated for RPL,

the $DC(P)$ analysis recovers $\{\text{DIO rank, DODAG version number}\}$ as the decision-critical set—precisely the fields TRAIL authenticates—derived analytically via the $\Delta D_r(I) \neq 0$ condition rather than from protocol-specific knowledge. This derivation method applies uniformly to any DV or link-state protocol by substituting the appropriate routing decision function.

8.6 Tamarin, ProVerif, and Formal Protocol Verification

Tamarin [22] and ProVerif [23] are the leading symbolic model-checkers for cryptographic protocols. Tamarin models protocols as multiset-rewriting systems in the applied pi-calculus and verifies guarded first-order logic lemmas; ProVerif translates protocols to Horn clauses and applies resolution-based verification. Both tools are sound with respect to the DY model and have been applied to TLS 1.3 [28], 5G AKA, WPA2, and industrial IoT protocols. Papers B and C of this research programme use Tamarin to verify lemmas about LoRaMesher and Meshtastic routing security; the baseline models falsify four lemmas (MetricAuthenticity, RouteFreshness, RouteConsistency, AuthorizedRoutes) and the patched models verify all eight in under 10 seconds each.

Tamarin and ProVerif are verification *tools*, not a security *theory*, and this distinction matters for three reasons. First, the tools verify lemmas but do not specify which lemmas to write or explain why those lemmas capture the relevant security property. The design-space questions—which fields are decision-critical, which authentication target is minimal, how the protocol’s message structure determines the attack surface—require a theory; Tamarin provides a mechanism for checking theory-derived claims. Second, each Tamarin model is protocol-specific, and there is no existing framework that explains why L1 MetricAuthenticity (LoRaMesher), L3 No_Relay_Takeover (Meshtastic), and the RPL rank-integrity lemma share the same logical structure or why their falsification implies the same attack class. Third, the DY attacker in Tamarin has no mechanism for expressing rate constraints; the physically-bounded attacker of PCSS would require resource counters in the multiset rewriting state that are absent from standard Tamarin.

PCSS provides the principled derivation of Tamarin lemma structure from protocol analysis. Given protocol P , the $DC(P)$ analysis (Definitions 2–4) identifies decision-critical message types; the $SBC(P)$ condition (Definition 6) translates directly to a Tamarin lemma schema:

$$\forall m. m \in DC(P) \wedge \text{Accepted}(i, m) \Rightarrow \exists k. \text{Honest}(k) \wedge \text{Sent}(k, m).$$

This is precisely the structure of L1 (Paper B) and L3 (Paper C). PCSS makes formal the informal reasoning by which those lemmas were originally chosen, and its falsification-implies-routing-violation argument (Theorem 1, contrapositively) explains *why* a failed Tamarin lemma constitutes a routing security breach.

Summary

9 DISCUSSION

9.1 PCSS vs. Dolev-Yao: Physical Bound as Key Differentiator

The central innovation of PCSS is the introduction of ρ^* as an *analysis primitive*, not merely an engineering constraint.

TABLE 7
Framework comparison: PCSS vs. prior work.

Framework	Physical bound?	Routing semantics?	Cross-protocol?
Dolev-Yao [1]	No	No	Yes (generic)
UC [3]	No	No	Yes (generic)
Non-interference [24]	No	No	Yes (generic)
LoRa surveys [26], [4]	Informal	Layer-based	No
TRAIL/RPL [7]	Informal	RPL-only	No
Tamarin/ProVerif [22]	No	Protocol-specific	No
PCSS (this work)	Yes (ρ^*)	DC(P), SBC(P)	Yes (L1–L4)

Classical DY analysis of LoRaMesher correctly flags the absence of HMAC as a vulnerability (a spoofed Hello can install A as next-hop). But DY analysis cannot distinguish between two patched configurations: (i) HMAC-SHA256 only, and (ii) HMAC-SHA256 + Hello rate below ρ^* . PCSS shows that configuration (ii) provides qualitatively stronger security: even a computationally unbounded attacker cannot accumulate the energy budget required to mount a persistent routing-table attack within window W .

9.2 L4 (Distributed Convergence) as Future Work

The current PCSS framework focuses on per-node routing table security (L1–L3) and the joint predicate (L4, Definition 3.37). A natural extension is to require *distributed convergence security*: the entire network’s routing tables should converge to a correct global state even in the presence of an adversary bounded by ρ^* . This requires a temporal logic argument over the protocol’s Bellman-Ford convergence dynamics and is deferred to future work.

9.3 Limitations

- (i) **PSK assumption.** Theorem 1 assumes a pre-shared key (PSK) infrastructure. Key distribution and revocation in multi-hop LoRa meshes is a separate research problem not addressed here.
- (ii) **Single-channel LoRa.** The ρ^* analysis models a single 868 MHz channel with one duty-cycle budget. Multi-channel operation or frequency hopping would increase ρ^* by a factor proportional to the number of independent channels.
- (iii) **Three protocols only.** PCSS has been instantiated on LoRaMesher, Meshtastic, and RPL. Extension to other DV protocols (e.g., OLSR, BATMAN) is straightforward but requires protocol-specific $DC(P)$ characterization.

10 CONCLUSION

We have presented the Physically-Constrained Semantic Security (PCSS) framework, a three-layer theory that integrates routing semantics, cryptographic binding, and physical execution cost into a single security predicate for IoT mesh routing protocols.

The key results are:

- **Theorem 1:** SBC is sufficient to exclude a Dolev-Yao attacker from all routing tables (2-node and n -hop).
- **Theorem 2:** ρ^* provides a closed-form physical feasibility bound; for the EoRa PI at SF9, the LoRaMesher

default Hello rate exceeds ρ^* by $20\times$, confirming that the silent black-hole attack is physically infeasible under HMAC-SHA256 authentication.

- **Theorem 3:** the joint PCSS predicate captures exactly the conditions under which neither semantic manipulation nor energy-amplified replay attacks can succeed.

PCSS provides a principled, cross-protocol answer to the question: “Is this routing configuration secure against a physically-bounded adversary?” By separating the semantic, cryptographic, and physical layers, PCSS can be incrementally applied: a protocol that satisfies SBC but not the ρ^* bound is still more secure than one that satisfies neither, and the framework quantifies exactly how much more secure.

Future work includes: Tamarin verification of the four SBC lemmas, extension of L4 to distributed convergence security, and empirical calibration of ρ^* on additional hardware platforms (Heltec V3, Seeed XIAO-S3).

REFERENCES

- [1] D. Dolev and A. C.-C. Yao, “On the security of public key protocols,” *IEEE Transactions on Information Theory*, vol. 29, no. 2, pp. 198–208, 1983.
- [2] ETSI, “ETSI EN 300 220-1: Short range devices (SRD) operating in the frequency range 25 MHz to 1 GHz,” European Telecommunications Standards Institute, Tech. Rep. EN 300 220-1 V3.1.1, 2017.
- [3] R. Canetti, “Universally composable security: A new paradigm for cryptographic protocols,” in *Proceedings of the 42nd IEEE Symposium on Foundations of Computer Science (FOCS)*, 2001, pp. 136–145.
- [4] E. Aras, G. Ramachandran, P. Lawrence, and D. Hughes, “Exploring the security vulnerabilities of LoRa,” pp. 1–6, 2017.
- [5] S. Tomasin, S. Zulian, and L. Vangelista, “Security analysis of LoRaWAN join procedure for internet of things networks,” pp. 1–6, 2017.
- [6] S. Raza, L. Wallgren, and T. Voigt, “SVELTE: Real-time intrusion detection in the internet of things,” vol. 11, no. 8, 2013, pp. 2661–2674.
- [7] P. Perazzo, C. Vallati, G. Anastasi, and G. Dini, “TRAIL: Secure path-aware routing for RPL,” in *Proceedings of the IEEE International Conference on Communications (ICC)*, 2017, pp. 1–7.
- [8] LoRaMesher Contributors, “LoRaMesher: Distance-vector routing for LoRa mesh networks,” GitHub repository, <https://github.com/LoRaMesher/LoRaMesher>, 2022.
- [9] Semtech Corporation, “SX1261/2 LoRa® transceiver datasheet,” <https://www.semtech.com/products/wireless-rf/lora-core/sx1262>, 2020.
- [10] Meshtastic Project, “Meshtastic: Open-source mesh networking for LoRa,” <https://meshtastic.org/docs/>, 2023.
- [11] T. Winter, P. Thubert, A. Brandt, J. Hui, R. Kelsey, P. Levis, K. Pister, R. Struik, J.-P. Vasseur, and R. Alexander, “RPL: IPv6 routing protocol for low-power and lossy networks,” IETF RFC 6550, 2012.
- [12] M. Bellare, R. Canetti, and H. Krawczyk, “Keying hash functions for message authentication,” in *Advances in Cryptology – CRYPTO 1996*, ser. Lecture Notes in Computer Science, vol. 1109. Springer, Berlin, Heidelberg, 1996, pp. 1–15.
- [13] J. Katz and Y. Lindell, *Introduction to Modern Cryptography*, 3rd ed. CRC Press, 2020.
- [14] C. Cremers and M. Dehnel-Wild, “Component-based formal analysis of 5g-AKA: Channel assumptions and session confusion,” in *Network and Distributed System Security Symposium (NDSS)*, 2019.
- [15] S. Goldwasser, S. Micali, and R. L. Rivest, “A digital signature scheme secure against adaptive chosen-message attacks,” *SIAM Journal on Computing*, vol. 17, no. 2, pp. 281–308, 1988.
- [16] M. Martínez-Bellver *et al.*, “LoRaMesher: An open-source library for LoRa mesh networks,” <https://github.com/LoRaMesher/LoRaMesher>, 2023.
- [17] Meshtastic Project, “Meshtastic: An open source, off-grid, decentralized, mesh network,” <https://meshtastic.org>, 2024.
- [18] A. Raoof, A. Matrawy, and C.-H. Lung, “Routing attacks and mitigation methods for RPL-based Internet of Things,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1669–1685, 2019.
- [19] H. Perrey, M. Landsmann, O. Ugus, M. Wählisch, and T. C. Schmidt, “TRAIL: Topology authentication in RPL,” in *IFIP Networking Conference*, 2016.
- [20] A. Dvir, T. Holczer, and L. Buttyan, “VeRA: Version number and rank authentication in RPL,” in *IEEE Mobile Ad Hoc and Sensor Systems (MASS)*, 2011.
- [21] R. for review], “Cross-protocol attack taxonomy: LoRaMesher vs. Meshtastic header semantics,” 2026, under submission.
- [22] S. Meier, B. Schmidt, C. Cremers, and D. Basin, “The TAMARIN prover for the symbolic analysis of security protocols,” in *Proceedings of the 25th International Conference on Computer Aided Verification (CAV)*, ser. Lecture Notes in Computer Science, vol. 8044. Springer, Berlin, Heidelberg, 2013, pp. 696–701.
- [23] B. Blanchet, “Modeling and verifying security protocols with the applied pi calculus and ProVerif,” vol. 1, no. 1–2, 2016, pp. 1–135.
- [24] J. A. Goguen and J. Meseguer, “Security policies and security models,” pp. 11–20, 1982.
- [25] M. R. Clarkson and F. B. Schneider, “Hyperproperties,” *Journal of Computer Security*, vol. 18, no. 6, pp. 1157–1210, 2010.
- [26] I. Butun, N. Pereira, and M. Gidlund, “Security risk analysis of LoRaWAN and future directions,” *Future Internet*, vol. 11, no. 1, p. 3, 2019.
- [27] A. Raoof, A. Matrawy, and C.-H. Lung, “Routing attacks and mitigation methods for RPL-based Internet of Things,” *IEEE Communications Surveys & Tutorials*, vol. 21, no. 2, pp. 1669–1685, 2019.
- [28] D. Basin, J. Dreier, L. Hirschi, S. Radomirovic, R. Sasse, and V. Stettler, “A formal analysis of 5G authentication,” in *Proceedings of the 2018 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, 2018, pp. 1383–1396.